



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie BSI TR-03176

IT-Sicherheitsanforderungen an die Datenübermittlung in der
Registermodernisierung

Version 1.0



Änderungshistorie

Version	Datum	Name	Beschreibung
0.5	03.11.2022	BSI, Referat DI 27	Erste Kommentierungsrunde
0.7	06.03.2023	BSI, Referat DI 27	Zweite Kommentierungsrunde
0.9	04.12.2023	BSI, Referat DI 27	Version für die öffentliche Kommentierung
0.96	29.08.2025	BSI, Referat D 25	Fassung nach grundlegender Überarbeitung, Anpassung an mittlerweile bekannte Architektur des NOOTS; Version zur Kommentierung durch BVA
0.97	29.10.2025	BSI, Referat D 25	Version für die öffentliche Kommentierung
0.98	13.03.2026	BSI, Referat D25	Version zur Abstimmung mit BVA, BMDS und FITKO mit dem Ziel der Verabschiedung durch den IT-Planungsrat. Rückmeldungen aus der öffentlichen Kommentierung wurden berücksichtigt. Das Kapitel zum Abruf der IDNr wurde aus der vorliegenden TR herausgenommen. Die Beschreibung allgemeiner Kommunikationsmodelle in Kapitel 3 wurde ersetzt durch eine Beschreibung der Kommunikation im NOOTS, die teilweise aus Kapitel 5 nach vorne gezogen wurde.
1.0	25.03.2026	BSI, Referat D25	Version zur Veröffentlichung

Tabelle 1: Versionshistorie

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: registermodernisierung@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2026

Danksagung

Das Bundesamt für Sicherheit in der Informationstechnik bedankt sich bei den vielen Organisationen, die bei der Erarbeitung dieser Technischen Richtlinie mit ihren Ansichten und Kommentaren tatkräftig mitgeholfen haben. Im Besonderen bedanken wir uns bei dem Bundesverwaltungsamt (BVA), der Föderalen IT-Kooperation (FITKO) sowie der Koordinierungsstelle für IT-Standards (KoSIT) für ihre sehr ausgiebige Unterstützung.

Inhalt

1	Einleitung.....	6
1.1	Thematische Einordnung.....	6
1.2	Zielgruppe	7
1.3	Aufbau der Technischen Richtlinie	7
1.4	Schlüsselwörter	7
2	Begriffsdefinitionen.....	9
3	Kommunikation im NOOTS	14
3.1	Rollen und Verantwortungsbereiche im NOOTS.....	17
4	Allgemeiner Anforderungskatalog.....	18
4.1	Allgemeine Anforderungen.....	18
4.2	Kommunikation über das NOOTS.....	19
5	Zentrale Komponenten des NOOTS.....	21
5.1	Protokollierung.....	21
5.1.1	Anforderungen an die Protokollierung	21
5.2	IAM für Behörden: Identifizierung und Authentifizierung technischer Komponenten.....	21
5.2.1	Identifizierung und Authentifizierung	22
5.3	Registerdatennavigation	23
5.3.1	Anforderungen an die Registerdatennavigation.....	23
5.4	Vermittlungsstelle: Abstrakte Berechtigungsprüfung.....	24
5.4.1	Anforderungen an die abstrakte Berechtigungsprüfung	24
5.5	Monitoring.....	25
6	Sichere Anschlussknoten.....	27
6.1	Build-, Release- und Deploymentmanagement.....	27
6.2	Kryptographische Anforderungen.....	28
6.3	Nachrichtenvvalidierung	29
6.4	Fehlerbehandlung.....	29
6.5	Sicherer Anschlussknoten für Data Consumer	29
6.6	Sicherer Anschlussknoten für Data Provider	30
	Literaturverzeichnis	32
	Abkürzungsverzeichnis.....	34

1 Einleitung

1.1 Thematische Einordnung

In der immer weiter voranschreitenden digitalisierten Welt steigt zunehmend auch das Interesse daran, die öffentlichen Verwaltungsleistungen digital erledigen zu können. Die Grundlage dafür bildet das Onlinezugangsgesetz (OZG). Darüber hinaus streben Bund, Länder und Kommunen die Umsetzung des sogenannten „Once-Only-Prinzips“ an. Dieses Prinzip soll es Bürgern bzw. Antragstellern ersparen, bereits an anderer Stelle in der öffentlichen Verwaltung zu ihnen vorliegende Informationen im Zuge eines Onlineantrages erneut angeben zu müssen. Dadurch können Anträge medienbruchfrei und digital vervollständigt werden, sodass auch das wiederholte Erfassen von Informationen durch die Behörde – bei entsprechender Zustimmung durch den Antragsteller oder rechtlicher Grundlage – entfällt. Im Rahmen des OZGÄndG wird die gesetzliche Grundlage für diesen automatisierten Datenaustausch in Form einer Änderung des E-Government-Gesetzes (EGovG) geschaffen. Das technische Fundament hierfür bilden eine Standardisierung der Datenhaltung in den Behörden und die Etablierung einer einheitlichen Kommunikationsinfrastruktur. Hierzu wurde am 6. April 2021 das Registermodernisierungsgesetz (RegMoG) verabschiedet, um die Modernisierung der Register in Bund, Ländern und Kommunen voranzutreiben. Dieses Gesetz sieht unter anderem die Einführung einer einheitlichen Identifikationsnummer für natürliche Personen (IDNr) in festgelegte Verwaltungsregister vor, um Daten in Verwaltungsverfahren eindeutig zuzuordnen. Durch das Unternehmensbasisdatenregistergesetz (UBRegG) wird darüber hinaus für juristische Personen eine bundeseinheitliche Wirtschaftsnummer für Unternehmen (beWiNr) eingeführt, welche als Identifikationsnummer für Unternehmen dienen soll. Dies ermöglicht die Etablierung neuer Standards zur Kommunikation und Datenübermittlung zwischen Behörden.

Zur Kommunikation zwischen den Registern und Onlinediensten wird gemäß NOOTS-Staatsvertrag (1) eine neue Infrastruktur, das Nationale Once-Only-Technical-System (NOOTS), errichtet. Das NOOTS wird die Teilnehmenden unter Nutzung sogenannter Sicherer Anschlussknoten (SAK) und zentraler Komponenten miteinander vernetzen. Es stellt die Erfüllung rechtlicher Vorgaben (wie die Zuordnung der IDNr zu Nachweisanfragen und die Berechtigungsprüfung im Sinne des Identifikationsnummergesetzes (IDNrG)) sicher und stellt notwendige Service (wie die Ermittlung der zuständigen nachweisliefernden Stellen und ein Datenmanagementsystem) zur Verfügung. Die Verbindung zum europäischen Once-Only-Technical-System im Sinne der SDG-Verordnung (Verordnung (EU) 2018/1724 des Europäischen Parlaments und des Rates vom 2. Oktober 2018) erfolgt über eine Intermediäre Plattform des NOOTS.

Der Übertragungsweg der Datenübermittlung im NOOTS stellt ein potentiellies Angriffsziel dar. Beispielsweise könnten Registerdaten abgefangen und/oder manipuliert werden oder verschiedene Registerdaten mithilfe der IDNr widerrechtlich zusammengeführt werden. Auch die zentralen Dienste des NOOTS, insbesondere das Berechtigungsmanagement, könnte in den Fokus von Angreifern geraten. Daher ist es notwendig, entsprechende Sicherheitsmechanismen zu etablieren.

Ziel dieser Technischen Richtlinie (TR) ist es daher, Anforderungen zu definieren, sodass bei deren korrekter Umsetzung Angriffe auf die Kommunikation im NOOTS nicht erfolgreich sind und ein sicherer sowie nachvollziehbarer Datenaustausch gewährleistet ist.

Grundlagen für die IT-Sicherheit der einzelnen Komponenten des NOOTS sind dem BSI-Grundsatz zu entnehmen. Diese Technische Richtlinie listet dementsprechend spezifische Anforderungen aus dem BSI-Grundsatz sowie darüber hinaus gehende Anforderungen auf. Des Weiteren wird angenommen, dass der Betreiber eines IT-Systems bereits notwendige betriebliche Maßnahmen, beispielsweise zur Sicherstellung eines angemessenen Verfügbarkeitsniveaus, getroffen hat.

Da der Datenaustausch über das NOOTS stets im Zusammenspiel mit weiteren Komponenten stattfindet, sind ergänzend zur vorliegenden Technischen Richtlinie zusätzliche Vorgaben zu beachten wie die

Technische Richtlinie zum Portalverbund (TR-03172). Vorgaben für anzuschließenden Stellen finden sich in der TR-03190 „IT-Sicherheitsanforderungen für die Anbindung an das NOOTS“.

Zu beachten ist darüber hinaus, dass die vorliegende Fassung dieser Technischen Richtlinie dem aktuellen Stand des NOOTS entspricht. Wichtige zentrale NOOTS-Komponenten werden derzeit noch konzipiert. Anforderungen an diese Komponenten werden abgestimmt und in der TR ergänzt bzw. angepasst, sobald der Planungsstand dies zulässt.

1.2 Zielgruppe

Diese TR richtet sich in erster Linie an die Entwickler und Betreiber der Komponenten des „Nationalen Once-Only-Technical-Systems“ (NOOTS). Ferner richtet sich die TR auch an die Betreiber und Entwickler der Anschlusssysteme an das EU-OOTS. Da einige in dieser Richtlinie formulierte Anforderungen nur durch das NOOTS und die angeschlossenen Systeme – wie Register, Onlinedienste und registerabfragende Behörden – gemeinsam umgesetzt werden können, können diese Informationen auch für die fach- und betriebsverantwortlichen Stellen der angeschlossenen Systeme von Interesse sein.

Essentiell für den Datenaustausch im NOOTS sind unter anderem die Sicheren Anschlussknoten (SAK). Diese stellen die Endpunkte der Kommunikation über das NOOTS dar und befinden sich im Verantwortungsbereich der DC bzw. DP. IT-Sicherheitsanforderungen an SAK sind im letzten Kapitel dieser Technischen Richtlinie zu finden. Hierbei ist zu beachten, dass die vorliegende Technische Richtlinie lediglich Anforderungen formuliert, die bei der Erstellung, Auslieferung und für die Software der SAK gelten. Anforderungen an den Betrieb und die Betriebsumgebung der SAK sowie weitere Anforderungen, die DC und DP beim Anschluss an das NOOTS mit Hilfe der SAK erfüllen müssen, finden sich in der TR-03190, die Anschlussbedingungen an das NOOTS auflistet, sowie für Onlinedienste und das Datenschutzcockpit in der TR-03172 Portalverbund (2).

1.3 Aufbau der Technischen Richtlinie

Diese Technische Richtlinie besteht aus mehreren Kapiteln, die sich den verschiedenen, für die IT-Sicherheit relevanten Komponenten des NOOTS widmen. Zunächst werden allgemeine Anforderungen aufgelistet, die im Kontext der TR stets zu erfüllen sind. Darauf folgen fachspezifische Kapitel.

Um die Anforderungen der einzelnen Kapitel eindeutig unterscheiden zu können, wird jede Anforderung mit einer eindeutigen Nummer versehen, bestehend aus:

1. Einem Präfix zur Markierung des Dokumententeils, in dem die Anforderung enthalten ist, z.B. A für Allgemein oder Z für Zentralkomponenten,
2. der Unterkapitelnummer und
3. einer fortlaufenden Nummer innerhalb des Unterkapitels, die ggf. weitere Untergliederungen erhält.

Enthält diese TR Verweise auf das IT-Grundschutz-Kompendium, so beziehen sich diese auf die Edition 2023 (3).

Die Technische Richtlinie repräsentiert den Stand der Technik und wird fortlaufend aktualisiert.

1.4 Schlüsselwörter

In der vorliegenden Technischen Richtlinie werden Anforderungen als Ausdruck normativer Festlegungen durch die in Großbuchstaben geschriebenen deutschen Schlüsselworte MUSS/MÜSSEN, DARF NICHT/DÜRFEN NICHT, SOLLTE/SOLLTEN entsprechend gekennzeichnet.

In den Anforderungen werden die in Versalien geschriebenen Modalverben „SOLLTE“ und „MUSS“ in ihren jeweiligen Formen sowie den zugehörigen Verneinungen genutzt, um deutlich zu machen, wie die jeweiligen Anforderungen zu interpretieren sind. Die hier genutzte Definition basiert auf RFC 2119 (4).

MUSS/DARF NUR:	Dieser Ausdruck bedeutet, dass es sich um eine Anforderung handelt, die unbedingt erfüllt werden muss (uneingeschränkte Anforderung).
DARF NICHT/DARF KEIN:	Dieser Ausdruck bedeutet, dass etwas in keinem Fall getan werden darf (uneingeschränktes Verbot).
SOLLTE:	Dieser Ausdruck bedeutet, dass eine Anforderung normalerweise erfüllt werden muss, es aber Gründe geben kann, dies doch nicht zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
SOLLTE NICHT/SOLLTE KEIN:	Dieser Ausdruck bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
KANN	Dieser Ausdruck bedeutet, dass eine bestimmte Umsetzung gewählt werden kann. Diese muss allerdings angezeigt werden.

2 Begriffsdefinitionen

Im Rahmen dieser Technischen Richtlinie werden Begriffe verwendet, die wie folgt definiert werden:

Begriff	Definition
Basisdaten	Stammdatensatz über eine natürliche Person oder ein Unternehmen im Sinne des § 4 IDNrG oder § 3 URegG
Basisregister	Register, welches Basisdaten vorhält. Es existiert das Basisregister des BZSt für natürliche Personen sowie das Basisregister des StBA für Unternehmen.
Betriebsverantwortliche Stelle eines NOOTS-Teilnehmers	Eine solche betriebsverantwortliche Stelle ist für den Betrieb eines oder mehrerer DC, DP und dazugehöriger SAK verantwortlich.
Betriebsverantwortliche Stelle des NOOTS	Öffentliche Stelle, die für den Betrieb und die Weiterentwicklung des NOOTS verantwortlich ist. Dazu gehören Aufgaben wie die Bereitstellung der technischen Infrastruktur und der Sicheren Anschlussknoten sowie der Anschluss von NOOTS Teilnehmern. Gemäß NOOTS-Staatsvertrag ist das Bundesverwaltungsamt (BVA) die Betriebsverantwortliche Stelle des NOOTS.
Berechtigte Teilnehmer	Berechtigte Teilnehmer des NOOTS sind öffentliche Stellen oder im Auftrag handelnde IT-Dienstleister, die über einen Sicheren Anschlussknoten (SAK) an das NOOTS angebunden sind und eine Berechtigung zum Abruf oder Bereitstellen von Nachweisen besitzen.
Bundeseinheitliche Wirtschaftsnummer für Unternehmen (beWiNr)	Nummer, die einem Unternehmen nach § 2 URegG zugeordnet wird.
Data Consumer (DC)	Technisches System, das Nachweisdaten anfordert. Im Verantwortungsbereich der Stelle, die den Data Consumer betreibt, befindet sich ein Sicherer Anschlussknoten (SAK).
Data Provider (DP)	Technisches System, das Nachweisdaten zum Abruf bereitstellt. Im Verantwortungsbereich der Stelle, die den Data Provider betreibt, befindet sich ein Sicherer Anschlussknoten (SAK).
Datenauthentisierungsverfahren	Im Kontext dieser Technischen Richtlinie werden unter dem Begriff Datenauthentisierung kryptographische Verfahren verstanden, die sicherstellen, dass übersandte oder gespeicherte Daten nicht durch unbefugte Personen und/oder Anwendungen verändert wurden (vgl. TR-02102-1 (5)).

Begriff	Definition
Datenmanagementsystem (DAMAS)	Das Datenmanagementsystem ist das zentrale Pflegesystem des NOOTS, das für die Verwaltung, Pflege und Bereitstellung von Metadaten zu Nachweisen, Datenkategorien und Berechtigungen zuständig ist. Die hinterlegten Daten über angebotene Nachweistypen, Abrufberechtigungen, Zuständigkeiten und Verbindungsinformationen dienen ihrerseits der Datenpflege zentraler NOOTS-Komponenten wie IAMfB, RDN und VS.
Ende-zu-Ende Verschlüsselung	Als Ende-zu-Ende-Verschlüsselung bezeichnet man eine Verschlüsselung der Fachnachricht, die gewährleistet, dass keine zwischengeschalteten Systeme Kenntnis über den Inhalt der Nachricht erwerben können. Im NOOTS liegen die Enden der Verschlüsselung in den SAK, da diese in der Verantwortung der sendenden bzw. empfangenden Stelle betrieben werden und somit die Daten, sobald sie den SAK erreichen, in die Verantwortung der entsprechenden Stelle übertragen wurden.
Fachdaten	Fachliche Daten; der genaue Aufbau dieses Nachrichtenformats wird durch den Standard (z.B. XNachweis) spezifiziert. Ein möglicher Inhalt dieser Fachdaten kann auch eine Anfrage sein mit dem Ziel, Daten abzurufen.
Fachnachricht	Nachricht, die die Fachdaten enthält; sie wird in der Regel als Teil einer Transportnachricht übertragen.
Fachverantwortliche Stelle	Öffentliche Stelle mit Zuständigkeit für das Fachrecht oder Vollzugszuständigkeit für Register, Fachverfahren oder Onlinedienste. Diese öffentliche Stelle kann den Betrieb eines IT-Systems beauftragen, das an das NOOTS angebunden wird.
Fachverfahren	Fachrechtliches Verwaltungsverfahren, welches digital oder analog umgesetzt wird. Ein Antragsverfahren muss dabei nicht zwingend Bestandteil des Fachverfahrens sein.
Fachsystem	Technisches System, beispielsweise ein Fachverfahren, Onlinedienst oder Register. Es kann als Fachnachrichten sendendes oder empfangendes System auftreten.
IAM für Behörden	Das IAM für Behörden ist ein zentrales System zur Zuordnung und zum Abruf berechtigungsrelevanter Informationen für Zugriffe auf Ressourcen gemäß rechtlichen Vorgaben.
Identifikationsnummer (IDNr)	Die Identifikationsnummer nach dem Identifikationsnummerngesetz. Sie wird als zusätzliches Ordnungsmerkmal in dort angegebenen Registern eingeführt, um eine natürliche Person eindeutig zu identifizieren.

Begriff	Definition
Identitätsdatenabruf (IDA)	Verfahren zum Abruf der Identifikationsnummer und anderer Basisdaten aus der Steuer-ID-Datenbank des Bundeszentralamtes für Steuern.
Identity Management für Personen (IDM für Personen)	Identitäts- und Zugriffsmanagement für Personen: Zentrale NOOTS-Komponente, die mit Hilfe des IDA-Verfahrens die Identifikationsnummer einer natürlichen Person ermittelt.
Nachweistyp	Nachweistypen klassifizieren Nachweise oder Nachweisdaten nach Zweck und Inhalt. Jeder Nachweis/Nachweisdaten sind eine konkrete, auf ein Objekt, eine natürliche oder juristische Person bezogene Ausprägung eines Nachweistyps. Beispiele für Nachweistypen sind die Daten der Zulassungsbescheinigung, Meldedaten oder Fahrerlaubnis.
NOOTS-Teilnehmer	Ein NOOTS-Teilnehmer ist ein im NOOTS registriertes technisches Verfahren zum Abruf oder zur Lieferung von Nachweisen. Konkret sind dies die über SAK angeschlossenen Data Provider und Data Consumer.
Öffentliche Stelle	Öffentliche Stellen sind Einrichtungen, die Aufgaben der öffentlichen Verwaltung im Auftrag von Bund, Ländern oder Kommunen wahrnehmen, darunter Behörden, Gerichte, Sozialversicherungsträger sowie Schulen und Hochschulen. Sie sind öffentlich-rechtlich organisiert und dienen der Allgemeinheit.
Onlinedienst	Digitaler Service, um Verwaltungsleistungen zu beantragen. In der Regel werden die Eingaben an ein Fachverfahren weitergeleitet und dort verarbeitet. Im Kontext von NOOTS treten Onlinedienste als Data Consumer (DC) auf.
Register	Ein Register ist eine Komponente, mit der die Datenbestände in der öffentlichen Verwaltung geführt werden. Im Rahmen dieser TR umfasst der Begriff „Register“ auch Spiegelregister oder Abrufportale, wenn diese bei Datenabrufen als Data Provider an die Stelle der eigentlichen Register treten.
Registerdatennavigation (RDN)	Die Registerdatennavigation ist eine zentrale NOOTS-Komponente und Routingdienst. Sie liefert auf Anfrage die Information, von welchem technischen Dienst einer Behörde ein gesuchter Nachweistyp abgerufen werden kann. Dazu übermittelt die RDN notwendige Verbindungsparameter.
Registermodernisierungsbehörde	Sammelbegriff für Aufgaben nach dem IDNrG, die dem BVA übertragen wurden.

Begriff	Definition
Sicherer Anschlussknoten (SAK)	Die Sicheren Anschlussknoten sind Komponenten, die für den Anschluss der NOOTS-Teilnehmer (Data Consumer und Data Provider) an das NOOTS verwendet werden. Sie übernehmen Aufgaben bei der Kommunikation mit den zentralen NOOTS-Komponenten und der Prüfung eingehender Nachrichten und sind für die Ver- und Entschlüsselung zuständig. Sie werden von der Betriebsverantwortlichen Stelle des NOOTS (BVA) zur Verfügung gestellt, aber von den Data Consumern und Data Providern in Eigenverantwortung betrieben.
Stand der Technik	„Stand der Technik ist der Entwicklungsstand fortschrittlicher Verfahren, Einrichtungen und Betriebsweisen, der nach herrschender Auffassung führender Fachleute das Erreichen des gesetzlich vorgegebenen Zieles gesichert erscheinen lässt. Verfahren, Einrichtungen und Betriebsweisen oder vergleichbare Verfahren, Einrichtungen und Betriebsweisen müssen sich in der Praxis bewährt haben oder sollten – wenn dies noch nicht der Fall ist – möglichst im Betrieb mit Erfolg erprobt worden sein.“ s. Handbuch der Rechtsförmlichkeit (6)
Token	Ein Token ist ein Datensatz, also eine Sammlung von Informationen, der durch den Herausgeber des Tokens gesiegelt wird und dessen Echtheit so für Dritte überprüfbar ist. Im NOOTS werden sie verwendet, um Eigenschaften zu attestieren, die eine Stelle geprüft hat. Sie sind so gestaltet, dass sie von weiteren Komponenten und NOOTS-Teilnehmern überprüft werden können.
Transportebene	Die Transportebene stellt eine Ebene dar, welche die Punkt-zu-Punkt-Kommunikation zwischen zwei miteinander verbundenen Systemen ermöglicht.
Transportanwendungsebene	Die Ebene der Transportanwendung (OSI-Schicht 7) ist technisch Teil der Anwendungsebene im ISO/OSI-Schichtenmodell. Sie erfüllt Mehrwertdienste für die Kommunikation (z.B. Postfach für asynchrone Kommunikation, Bestimmung des technischen Leitweges auf Basis einer fachlichen Adressierung, Weiterleitung von Nachrichten) und verarbeitet hierfür gegebenenfalls Metadaten. Beispiele für Kommunikationsprotokolle auf dieser Ebene sind eDelivery AS4, HTTPS in Verbindung mit Regelungen zur Ausgestaltung der Schnittstellen, OSCI-Transport oder X-Road.

Begriff	Definition
Transportnachricht	Nachricht der Transportanwendungsebene (OSI-Schicht 7), welche die Fachnachricht enthält, sowie Metadaten, die für die Ausübung der Aufgaben der Transportebene notwendig sind. Der Aufbau der Nachricht wird durch das auf der Transportanwendungsebene verwendete Protokoll bestimmt.
Transportverschlüsselung	Als Transportverschlüsselung bezeichnet man eine Verschlüsselung der Fachnachricht auf der Transportebene, beispielsweise mittels TLS.
Vermittlungsstelle (VS)	Die Vermittlungsstelle erfüllt als Autorisierungskomponente die Aufgabe, bei Nachweisabrufen eine abstrakte Berechtigungsprüfung durchzuführen.
XBasisdaten	Standard zum Abrufen von Basisdaten über natürliche Personen
XNachweis	Standard zum Abrufen von Nachweisdaten
XUnternehmen.Basisregister	Standard zum Abrufen von Basisdaten über Unternehmen
Zentrale Monitoring-Komponente (des NOOTS)	Zentrale Komponente der Sicherheitsarchitektur, die kontinuierlich alle Aktivitäten im System überwacht, Auffälligkeiten erkennt und bei Bedarf sofortige Maßnahmen wie z.B. temporäre Sperrung von Teilnehmern einleitet. Diese Komponente wird vom Bundesverwaltungsamt (BVA) als betriebsverantwortliche Stelle des NOOTS umgesetzt. Sie wird auch als Sicherheitsaudit bezeichnet.
Zentrale NOOTS-Komponente	Dieser Begriff bezeichnet die vom BVA bereitgestellten zentralen Komponenten des NOOTS. Nach derzeitiger Planung umfasst dies das IDM für Personen, das IAM für Behörden, die Registerdatennavigation, die Vermittlungsstelle, die Intermediäre Plattform, die zentrale Monitoring-Komponente sowie das Datenmanagementsystem DAMAS.

3 Kommunikation im NOOTS

Das Nationale Once-Only-Technical-System (NOOTS) stellt eine zentrale Infrastruktur da, die den digitalen Austausch von Nachweisen zwischen Registern und Onlinediensten und perspektivisch auch in weiteren Anwendungsfällen ermöglicht. Die Rolle des NOOTS besteht dabei nicht nur aus dem Transport, sondern auch aus dem Berechtigungsmanagement und der Absicherung der Datenübertragungen.

Die Kommunikation im NOOTS nutzt als zugrunde liegendes Transportnetz derzeit das Internet. Um die Kommunikation abzusichern, sind die NOOTS-Teilnehmer, also Data Consumer (DC) und Data Provider (DP), die jeweils Nachweise anfordern bzw. versenden, über Sichere Anschlussknoten (SAK) mit dem NOOTS verbunden. Die rechtliche Grundlage für das durch die SAK aufgespannte Kommunikationsnetz bildet die NOOTSNetzV.

An die SAK angebunden werden die eigentlichen Endpunkte der Kommunikation, nämlich einerseits die Data Consumer (DC) als Fachsysteme, welche einen Nachweis anfordern, und die Data Provider (DP) als Fachsysteme, die einen Nachweis zur Verfügung stellen. Für die Anbindung der DC wird vom BVA als betriebsverantwortliche Stelle des NOOTS ein auf die Anforderungen der DC zugeschnittener SAK zur Verfügung gestellt, für die Anbindung der DP ein entsprechender SAK für DP.

Um Nachweisabrufe über das NOOTS zu ermöglichen, ist ein hoher Grad an Interoperabilität zwischen dem Onlinedienst oder Fachverfahren einerseits und dem Register andererseits erforderlich. Zu diesem Zweck wurde durch das BVA der Standard XNachweis herausgegeben. Der Standard legt verbindlich die Datenstruktur für Nachweisabrufe innerhalb des NOOTS fest. Der Standard orientiert sich hierbei an den Technischen Entwurfsdokumenten (TDDs) des europäischen Once-Only-Technical-Systems (EU-OOTS).

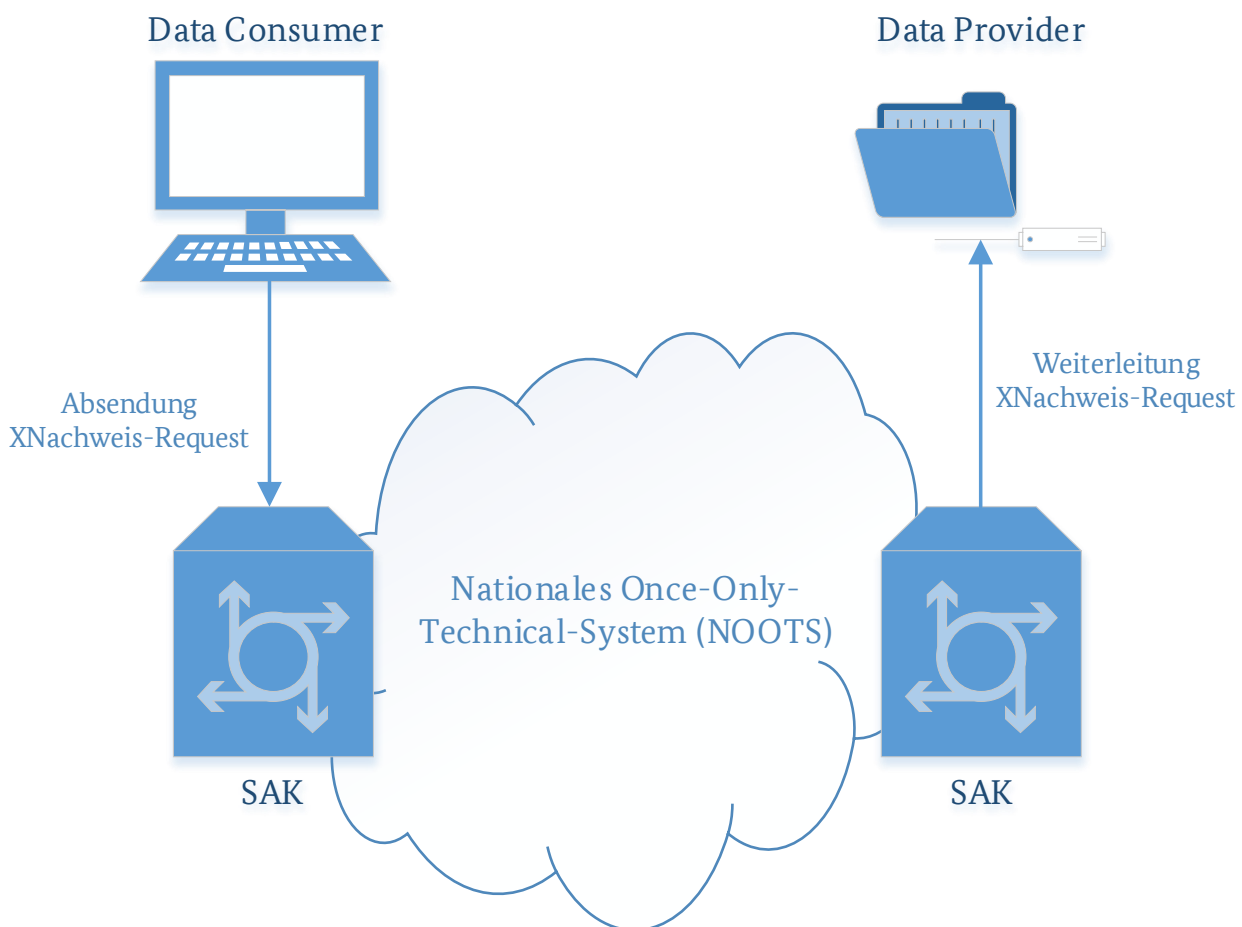


Abbildung 1: Nachweisabruf über das NOOTS mit Hilfe von SAK

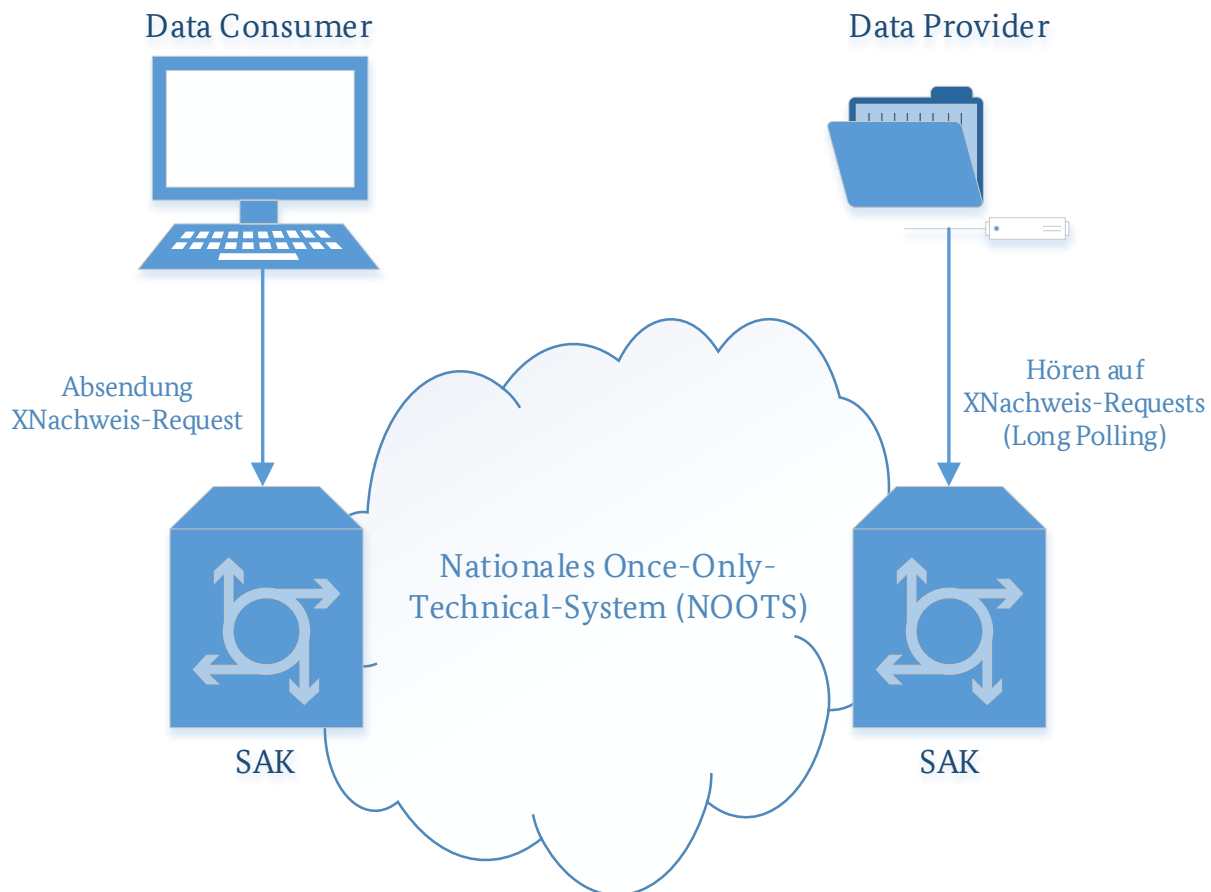


Abbildung 2: Nachweisabruf mittels Long Polling

Die übertragenen Nachweise können beispielsweise in maschinenlesbarer Form vorliegende Dokumente sein. Perspektivisch ist allerdings der Umbau der Akteure so vorgesehen, dass nur noch einzelne Auszüge aus Einzeldokumenten oder gar Atteste darüber, ob eine bestimmte Aussage (z.B. „minderjährig“) zutrifft, übermittelt werden müssen. Die Kommunikation läuft dabei entsprechend der Abbildung 1 ab.

Da sich manche Data Provider in besonders gesicherten Netzen befinden, in denen spezielle Vorgaben für den Datentransfer gelten, ist als alternative Anbindungsmöglichkeit auch Long Polling zwischen SAK und DP geplant, wie in Abbildung 2 dargestellt. Hierbei agiert der DP als "aktiver Empfänger", d.h. er sendet wiederholt Anfragen an seinen SAK, ob neue Nachweis-Anfragen dort eingegangen sind. Der SAK des DP antwortet bei Vorliegen einer Nachweis-Anfrage mit dem Weiterleiten dieser. Andernfalls terminiert der SAK des DP die Verbindung nach einer vordefinierten Wartezeit und der DP sendet eine neue Anfrage.

Zur Durchführung des Nachweisabrufs sind zusätzlich zu den SAK verschiedene zentrale NOOTS-Komponenten notwendig. Hierzu gehören das IAM für Behörden, welches der Identifizierung und Authentifizierung der angebundenen Systeme dient, die Registerdatennavigation (RDN) zur Bestimmung des zuständigen Data Providers, sowie die Vermittlungsstelle (VS), die eine abstrakte Berechtigungsprüfung durchführt. Zusätzlich zu diesen drei Komponenten findet im NOOTS ein zentrales Monitoring statt. IT-Sicherheitsanforderungen an diese vier Komponenten werden in der vorliegenden TR aufgeführt. Weitere zentrale Komponenten des NOOTS werden derzeit noch konzipiert. Nach erfolgter Abstimmung der Rahmenarchitektur dieser Komponenten durch FITKO und BVA werden entsprechende Anforderungen in dieser TR veröffentlicht.

Damit IAM für Behörden, Registerdatennavigation (RDN) sowie Vermittlungsstelle (VS) ihrer jeweiligen Aufgabe nachkommen können, müssen sie mit Daten über angeschlossene NOOTS-Teilnehmer (DC und DP) sowie die zwischen ihnen bestehenden Abrufberechtigungsbeziehungen versorgt werden. Diese Daten sollen über ein Datenmanagementsystem (DAMAS) zur Verfügung gestellt werden, das seinerseits auf die aktive Befüllung durch betriebs- und fachverantwortliche Stellen angewiesen ist.

Darüber hinaus ist für den Betrieb des NOOTS eine Methode zur Abfrage der zu einer natürlichen Person gehörigen IDNr notwendig, wozu die Komponente IDM für Personen dient. Wird diese genutzt, müssen die Register, das Verfahren des BVA zum Identitätsdatenabruf (IDA) und ggf. auch die Online-Dienste an das Datenschutzcockpit (DSC) angeschlossen sein, das es Bürgerinnen und Bürgern ermöglicht, Datenaustausche zu ihrer IDNr nachzuvollziehen. IT-Sicherheitsanforderungen an diese Komponente finden sich in der TR-03172 zum Thema Portalverbund.

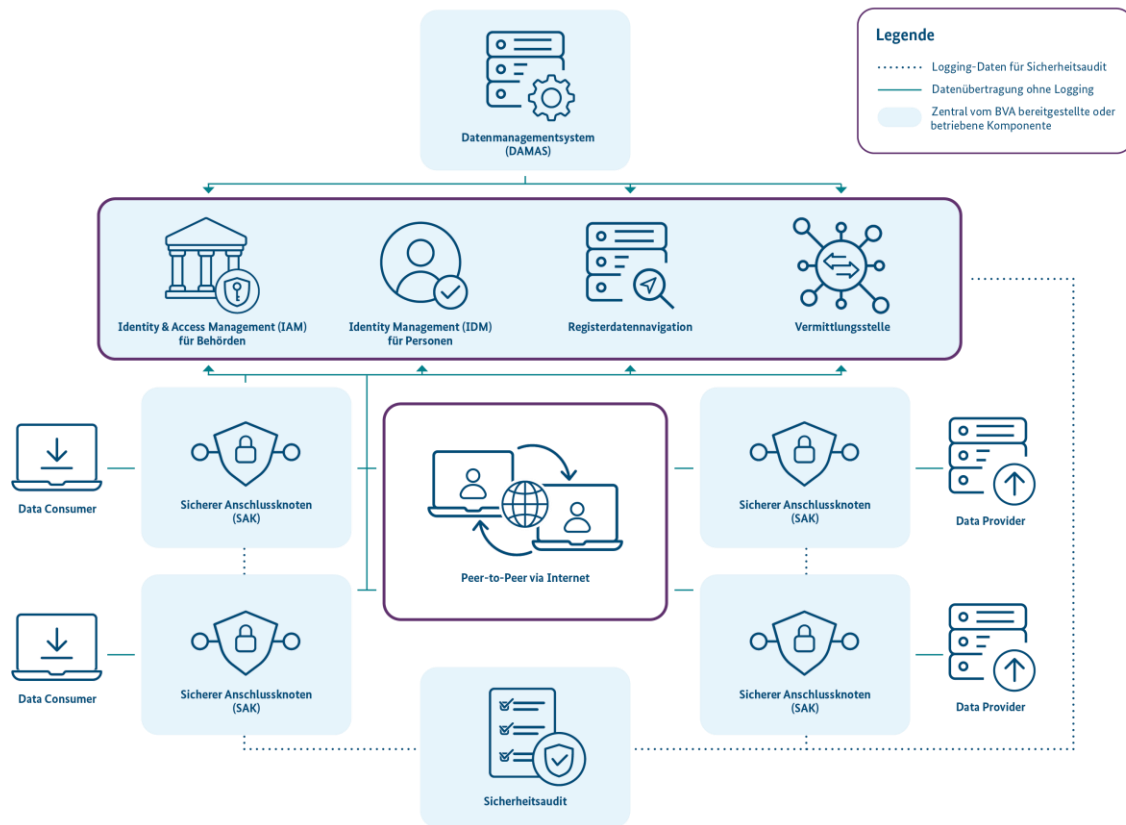


Abbildung 3: Transportinfrastruktur NOOTS

Diese teilweise auch in Abbildung 3 dargestellten Komponenten des NOOTS wirken im Rahmen eines Nachweisabrufs wie folgt zusammen:

Der Nachweisabruf wird von einem Nutzer initiiert. Dieser meldet sich an einem Onlinedienst an und stößt beispielsweise im Rahmen eines Onlineantrages, für den Nachweise benötigt werden, einen Nachweisabruf über das NOOTS an. Der Onlinedienst nimmt im NOOTS die Rolle des DC ein und verwendet seinen SAK, um von der zentralen NOOTS-Komponente IAM für Behörden ein gesiegeltes Token zur Attestierung seiner Zugriffsberechtigung zu erhalten. Falls die Anfrage durch einen Onlinedienst aus dem europäischen Ausland gestellt wird, wird sie über die Intermediäre Plattform geleitet, die in diesem Fall die Rolle des DC annimmt.

Im nächsten Schritt ermittelt der SAK des DC mit Hilfe der RDN, ob für den Abruf des Nachweises weitere Parameter wie die IDNr oder beispielsweise die Postleitzahl der anfragenden Person notwendig sind. Hierbei erhält der SAK des DC von der RDN ein gesiegeltes Zuständigkeitstoken.

Daraufhin kontaktiert der SAK des DC die Vermittlungsstelle (VS): Hier findet eine abstrakte Berechtigungsprüfung statt, bei der die VS ohne Einblick in die tatsächliche Nachweisanfrage prüft, ob der anfragende DC die Berechtigung zum Abruf des angefragten Nachweistyps besitzt. Im Erfolgsfall bestätigt er

dies dem SAK des DC mit dem gesiegelten Abruftoken. Ggf. wird die IDNr danach vom SAK über das IDM für Personen abgerufen.

Mit allen dazu notwendigen Informationen und Token kann der SAK des DC in einem erneuten Abruf von der RDN die Verbindungsparameter des Registers erhalten, aus dem der angefragte Nachweis abgerufen werden kann.

Um den Nachweis zu erhalten, kontaktiert der SAK des DC schließlich direkt den SAK des DP, der den Nachweis liefern soll. Hierzu wird die Nachweisanfrage genau wie später der vom DP gelieferte Nachweis zusätzlich zur TLS-Verschlüsselung einer Inhaltsdatenverschlüsselung unterzogen. Im Gegensatz zur TLS-Verschlüsselung, die an zwischengeschalteten Systemen aufgebrochen werden kann, ist die Inhaltsdatenverschlüsselung hier eine Ende-zu-Ende-Verschlüsselung, die die Vertraulichkeit und Integrität der Daten beim Transport vom SAK des DC im Verantwortungsbereich des DC bis zum SAK des DP im Verantwortungsbereich des DP hinein schützt.

Der gesuchte Nachweis kann hierbei in einem deutschen Register liegen oder auch in einem anderen europäischen Staat. Im letzteren Fall tritt die Intermediäre Plattform in die Rolle des DP.

Der SAK des DP prüft beim Erhalt der Anfrage zunächst sämtliche Token. Hierbei prüft er unter anderem mit Hilfe des entsprechenden Tokens die Authentifizierung des anfragenden DC gegenüber dem IAM für Behörden. Auch eine Schemavalidierung der Nachricht wird durchgeführt. Schließlich leitet der SAK des DP die Nachricht an den DP weiter. Sämtliche Token werden an den DP weitergeleitet, so dass dieser die Validierungen ebenfalls durchführen kann.

Die Antwort des DP wird im SAK des DP für den SAK des DC verschlüsselt und wiederum direkt an diesen gesendet. Der SAK des DC prüft die Siegelung durch den SAK des DP. Der SAK des DC führt in diesem Schritt zusätzlich zur Schemavalidierung der Nachricht eine Virenprüfung durch, bevor die Nachricht an den DC weitergeleitet wird.

Bei jedem Nachweisabruf senden die SAK und die zentralen NOOTS-Komponenten Protokolldaten an die zentrale Monitoring-Komponente des NOOTS. Für diese Komponente wird je nach Kontext auch der Begriff „Sicherheitsaudit“ synonym verwendet. Mit Hilfe der gesammelten Daten kann die Monitoring-Komponente Auffälligkeiten detektieren und automatisiert Komponenten vom NOOTS trennen, die eine Gefahr darstellen könnten. Dies geschieht im Falle von DC, indem diese keine Zugriffstoken vom IAM für Behörden mehr erhalten. Treten die Auffälligkeiten bei einem DP auf, gibt die RDN für diesen kein Zuständigkeitstoken mehr aus.

In einem manuellen Prozess werden diese Auffälligkeiten geklärt und die Komponenten ggf. wieder freigegeben.

3.1 Rollen und Verantwortungsbereiche im NOOTS

Im NOOTS ist jedem NOOTS-Teilnehmer genau eine fach- und eine betriebsverantwortliche Stelle zugeordnet. Die fachverantwortliche Stelle trägt die fachrechtliche Verantwortung, während die Rolle der betriebsverantwortlichen Stelle beispielsweise von einem Dienstleister eingenommen werden kann, der sich um die Umsetzung der technischen Anforderungen und den Betrieb kümmert.

Das NOOTS als technisches System wird in seiner Gesamtheit vom BVA als betriebsverantwortliche Stelle des NOOTS konzipiert und umgesetzt. Das BVA erstellt und betreibt die zentralen Komponenten des NOOTS. Auch die SAK werden vom BVA konzipiert und den DC und DP zur Verfügung gestellt. Aktuell ist geplant, die SAK für DC mandantenfähig auszulagern, so dass an einen SAK mehrere DC mit unterschiedlichen fachverantwortlichen Stellen angeschlossen sein können. Jeder SAK besitzt genau eine betriebsverantwortliche Stelle, die mit der betriebsverantwortlichen Stelle der an diesen SAK angeschlossenen DC bzw. DP übereinstimmt. Die betriebsverantwortliche Stelle eines DC bzw. DP wird durch die jeweilige fachverantwortliche Stelle des DC bzw. DP bestimmt.

4 Allgemeiner Anforderungskatalog

Das BVA als die betriebsverantwortliche Stelle des NOOTS muss die in dieser TR aufgelisteten Anforderungen beachten. Teilweise muss die Umsetzung dieser Anforderungen in den angebundenen Systemen oder unter Mitwirkung der angebundenen Systeme erfolgen. Dieser Anforderungskatalog stellt dennoch ausdrücklich keine abschließende Liste der Anforderungen an angebundene Systeme dar, wie man sie in TR-03190 findet, sondern richtet sich ausschließlich an das BVA und ihre Dienstleister als Verantwortliche für die zentralen NOOTS-Komponenten sowie für die Entwicklung und Bereitstellung der SAK.

4.1 Allgemeine Anforderungen

- [A.1.1] Die BSI-Standards 200-1 (7), 200-2 (8) und 200-3 (9) oder die Vorgaben der ISO/IEC 27001 (10) MÜSSEN in der jeweils geltenden Fassung umgesetzt werden. Als Mindestniveau MUSS die Standard-Absicherung für den betreffenden Informationsverbund gewählt werden. Das IT-Grundschutz-Kompendium MUSS in der aktuellen Version verwendet werden, wobei eine Übergangsfrist von 3 Jahren bzw. eine Frist bis zum Jahr 2029 für die Umstellung auf Grundschutz++ zulässig ist.
- [A.1.2] Der BSI-Standard 200-4 (11) oder die Vorgaben der ISO-Norm 22301:2019 (12) MUSS bzw. MÜSSEN in der jeweils geltenden Fassung umgesetzt werden. Schnittstellen zu angeschlossenen Diensten MÜSSEN bewertet und behandelt werden. Es MÜSSEN im Rahmen des Notfallmanagements Maßnahmen getroffen werden, wie mit Sicherheitsvorfällen umzugehen ist.
- [A.1.3] Alle zentralen Komponenten des NOOTS MÜSSEN vor der Inbetriebnahme mindestens mittels eines Penetrationstests bzw. Webchecks überprüft werden. Dieser MUSS spätestens nach 3 Jahren oder bei größeren Änderungen wiederholt werden. Die Ergebnisse dieser Tests MÜSSEN dem Bundesamt für Sicherheit in der Informationstechnik auf Nachfrage zur Verfügung gestellt werden.
- [A.1.4] Jede zentrale NOOTS-Komponente und die SAK MÜSSEN einem externen Code-Audit unterzogen werden. Dieser MUSS spätestens nach 3 Jahren oder bei größeren Änderungen wiederholt werden. Die Ergebnisse dieser Überprüfungen MÜSSEN dem Bundesamt für Sicherheit in der Informationstechnik auf Nachfrage zur Verfügung gestellt werden.
- [A.1.5] Die Verantwortlichen MÜSSEN die Verfügbarkeitsanforderungen an die zentralen Komponenten des NOOTS dokumentieren und die Architektur der beteiligten Systemkomponenten daran ausrichten. Dies umfasst Maßnahmen zur Redundanz (z.B. Mehrfachserver, mehrere Standorte), zum kontinuierlichen Monitoring und Erkennen von Ausfällen sowie zur Minimierung von Ausfallzeiten.
- [A.1.6] Bei der Ermittlung der Verfügbarkeitsanforderung MÜSSEN die potentielle Nutzerbasis sowie eventuelle Stichtage und Fristen im Fachverfahren berücksichtigt werden, die zu Lastspitzen bzw. erhöhten Zugriffszahlen auf den Dienst führen können. Es SOLLTEN Lasttests durchgeführt werden, um die Skalierbarkeit und Stabilität der Infrastruktur zu gewährleisten.
- [A.1.7] Es MUSS regelmäßig (mindestens jedoch einmal jährlich) evaluiert werden, ob die zentralen NOOTS-Komponenten die Anforderungen an Verfügbarkeit, Performanz und Skalierbarkeit erfüllen, die sich aus dem Betrieb ergeben. Werden sie nicht erfüllt, MÜSSEN Maßnahmen ergriffen werden, um die Anforderungen zu erfüllen.
- [A.1.8] Im Sicherheitskonzept MUSS der Reaktionsprozess bei Bekanntwerden einer Schwachstelle auf Basis ihrer Kritikalität klar definiert sein. Der Reaktionsprozess MUSS allen Beteiligten bekannt sein. Der Weiterbetrieb des NOOTS bei bekannter Schwachstelle DARF NICHT länger sein als die im Sicherheitskonzept auf Basis der Kritikalität definierte Übergangsfrist. Es MUSS eine security.txt nach RFC 9116 (13) implementiert und regelmäßig aktualisiert werden.
- [A.1.9] OPS.1.1.3.A15 („Regelmäßige Aktualisierung von IT-Systemen und Software“) und CON.8.A20 („Überprüfung von externen Komponenten“) des IT-Grundschutz-Kompendiums MÜSSEN eingehalten werden. Insbesondere MÜSSEN an der Kommunikation beteiligte Systeme, die erforderliche Aktualisierungen nicht durchgeführt haben, erkannt und ausgeschlossen werden.

- [A.1.10] Die Produktivumgebung MUSS von weiteren Betriebsumgebungen getrennt betrieben werden. Zusätzlich SOLLTEN weitere Betriebsumgebungen für verschiedene Zwecke voneinander getrennt betrieben werden (z. B. Entwicklungsumgebung, Testumgebung, Stagingumgebung).
- [A.1.11] Während des gesamten Lebenszyklus der Software der zentralen NOOTS-Komponenten sowie der SAK MÜSSEN die Vorgaben der TR-03185 (14) oder eines vergleichbaren Standards berücksichtigt werden.
- [A.1.12] Es muss ein Software-Bill-of-Materials (SBOM) gemäß TR-03183-2 (15) erstellt werden.
- [A.1.13] Eingesetzte (Dritt-) Software MUSS in einer Version verwendet werden, die mit Sicherheitsupdates versorgt wird. Wenn für die Anwendung relevante Schwachstellen in verwendeter Software bekannt werden, MÜSSEN die zugehörigen Sicherheitsupdates kurzfristig eingespielt werden. Die Umsetzungszeit MUSS der Kritikalität und Ausnutzbarkeit der Schwachstelle entsprechend angemessen gewählt werden. Software, die nicht länger vom Hersteller oder Entwickler gewartet wird, DARF NICHT verwendet werden.
- [A.1.14] Ein Prozess für den Umgang mit Responsible-Disclosure-Meldungen MUSS etabliert sein.
- [A.1.15] Das Prinzip der Datensparsamkeit MUSS eingehalten werden: Jede Komponente des NOOTS darf nur die Daten einsehen und verarbeiten, die zur Erfüllung der ihr zugewiesenen Aufgaben nötig sind.
- [A.1.16] Zur Umsetzung der Vorgaben aus der DSGVO SOLLTE das Standard-Datenschutz-Modell (SDM) (16) herangezogen werden.
- [A.1.17] Die kryptographischen Vorgaben des BSI gemäß TR-02102-1 MÜSSEN von den zentralen Komponenten des NOOTS umgesetzt werden.
- [A.1.18] Es MUSS ein Konzept entwickelt werden, welches für den Fall der Weiterentwicklung der Verschlüsselungs- bzw. Datenauthentisierungsverfahren oder des Diebstahls von Schlüsseln oder Ähnlichem den Austausch der Verfahren und/oder des kryptographischen Materials ermöglicht und zwingend vorschreibt (Kryptoagilität).
- [A.1.19] Die zur Kommunikation verwendeten Verschlüsselungsverfahren insbesondere für die Inhaltsdatenverschlüsselung SOLLTEN quantensicher sein. Im Falle von Schlüsselaustauschverfahren bedeutet das, dass eine Kombination aus klassischen und quantensicheren Verfahren verwendet werden SOLLTE. Im Falle von symmetrischer Verschlüsselung MUSS eine ausreichende Schlüssellänge verwendet werden.

4.2 Kommunikation über das NOOTS

Alle am Nachweisabruf beteiligten technischen Systeme MÜSSEN die Identität ihrer Kommunikationspartner anhand mehrerer, voneinander unabhängiger und kryptographisch abgesicherter Faktoren überprüfen. Einen dieser Faktoren kann das Zugriffstoken der zentralen NOOTS-Komponente IAM für Behörden darstellen.

- [A.2.2] Schlägt die Überprüfung der Teilnahmerechtigung, Identifizierung oder Authentifizierung eines Kommunikationspartners fehl, DARF die von diesem Kommunikationspartner erhaltene Nachricht NICHT verarbeitet werden.
- [A.2.3] Sowohl Data Consumer (DC) als auch Data Provider (DP) MÜSSEN für jeden Nachweisabruf über das NOOTS einen Sicheren Anschlussknoten (SAK) verwenden.
- [A.2.4] Für jedes an der Kommunikation teilnehmende System MUSS ein Verweis auf eine Stelle, die zur manuellen Klärung von Fehlern oder zur Meldung von Fehlern kontaktiert werden kann, vorliegen und innerhalb der Kommunikationsinfrastruktur allgemein bekannt sein.
- [A.2.5] Die Log-Dateien und die Log-Level, die den Detailgrad der Log-Dateien festlegen, MÜSSEN dem Schutzbedarf entsprechend mit geeigneten Maßnahmen vor Manipulation geschützt werden.
- [A.2.6] Die zentralen NOOTS-Komponenten IAM für Behörden, RDN, VS und IDM für Personen sowie die SAK der DC und die SAK der DP MÜSSEN der zentralen Monitoring-Komponente des NOOTS Protokolldaten über die bearbeiteten Prozessschritte im Rahmen eines Nachweisabrufs übermitteln. Die Liste der protokollierten Prozessschritte MUSS mindestens die in den Abschnitten 5.2.1, 5.3.1, 5.4.1, 6.5 und 6.6 benannten zu protokollierenden Prozessschritte abdecken.
- [A.2.7] Inhalt der Protokolldaten aus Anforderung [A.2.6] MUSS mindestens der zugehörige Prozessschritt innerhalb des Nachweisabrufs, der Zeitpunkt der Verarbeitung, der Fehlercode und die Identifikatoren der an der Kommunikation beteiligten technischen Komponenten sein. Die Protokolldaten DÜRFEN

KEINE personenbezogenen Daten enthalten. Die den gleichen Nachweisabruf betreffenden Protokolle MÜSSEN einander zuordenbar sein.

[A.2.8] Die Protokolldaten aus Anforderung [A.2.6] MÜSSEN von den jeweiligen protokollierenden technischen Komponenten gesiegelt und gemäß TR-02102-2 mittels mTLS transportverschlüsselt werden.

5 Zentrale Komponenten des NOOTS

Unter den zentralen Komponenten des NOOTS werden die technischen Systeme verstanden, die vom BVA als betriebsverantwortliche Stelle des NOOTS betrieben werden. Hierbei werden nicht alle zentralen Komponenten für jeden Nachweisabruf benötigt.

Im Rahmen der aktuellen Version dieser Technischen Richtlinien werden die zentralen NOOTS-Komponenten IAM für Behörden, Registerdatennavigation (RDN), Vermittlungsstelle (VS) und zentrale Monitoring-Komponente betrachtet. Weitere zentrale NOOTS-Komponenten sind derzeit in Entwicklung. Sobald die Konzeptionierung und der Abstimmungsprozess es zulassen, werden Anforderungen an diese weiteren Komponenten in der vorliegenden Technischen Richtlinie ergänzt.

5.1 Protokollierung

Zur Sicherstellung einer gesetzeskonformen, transparenten und nachvollziehbaren Datenverarbeitung sowie zur Möglichkeit der Detektion von sicherheitskritischen Ereignissen ist die Führung von Protokollen und Logs durch die zentralen NOOTS-Komponenten erforderlich. Diese Richtlinie betrachtet hierbei fokussiert technische Protokolle, welche in erster Linie der Informationssicherheit dienen. Hiervon abzugrenzen sind fachliche Protokolle, insbesondere diejenigen nach §9 IDNrG. Die rechtlichen Vorgaben für den Inhalt dieser Protokolle sind nicht Gegenstand dieser Richtlinie. Falls im Rahmen der Risikoanalyse ein entsprechender Schutzbedarf gesehen wird, kann die Umsetzung ausgewählter Maßnahmen der IT-Grundsichtbausteine OPS.1.1.5 (Protokollierung) und OPS.1.2.2 (Archivierung) für die Absicherung dieser fachlichen Protokolle nötig sein.

Folgende Anforderungen sind an die technische Protokollierung in den Zentralkomponenten IAM für Behörden, RDN und VS zu richten. Spezielle Anforderungen und Protokollierungssituationen sind in den darauffolgenden Unterkapiteln zu finden.

5.1.1 Anforderungen an die Protokollierung

- [Z.1.1] Es MUSS ein Protokoll über alle betriebs- und sicherheitsrelevanten Ereignisse geführt werden. Dies schließt die Protokollierung von Änderungen am Datenbestand der zentralen NOOTS-Komponenten mit ein. Dabei MUSS der Mindeststandard des BSI zur Protokollierung und Detektion von Cyberangriffen (17) umgesetzt werden.
- [Z.1.2] Zur Führung der Protokolle MUSS der BSI-IT-Grundsichtbaustein OPS.1.1.5 („Protokollierung“) umgesetzt werden. Hierbei MÜSSEN neben den Basis-Anforderungen auch die Standard-Anforderungen sowie die Anforderung OPS.1.1.5.A11 („Steigerung des Protokollierungsumfangs“) des IT-Grundsicht-Kompandiums umgesetzt werden. Die weiteren Anforderungen für erhöhten Schutzbedarf SOLLTEN umgesetzt werden, sofern hierfür im Rahmen der Risikoanalyse ein Bedarf gesehen wird.
- [Z.1.3] Die IDNr gemäß IDNrG DARF NICHT im Rahmen der Protokolle gespeichert werden. Andere identifizierende personenbezogene Daten sowie die bundeseinheitliche Wirtschaftsnummer für Unternehmen gemäß URegG und andere Identifikationsnummern nach § 3 Abs. 3 URegG DÜRFEN NICHT im Rahmen der Protokolle gespeichert werden.

5.2 IAM für Behörden: Identifizierung und Authentifizierung technischer Komponenten

Zu Beginn jedes Nachweisabrufes über das Nationale Once-Only-Technical-System (NOOTS) müssen sich DCs zunächst vom IAM für Behörden (IAMfB) ein Zugriffstoken für ihre Teilnahme am Abrufprozess über das NOOTS ausstellen lassen. Dem IAM für Behörden kommt also eine zentrale Rolle zu, berechnete Teilnehmer zu identifizieren und zu authentifizieren. Diese Funktion kann das IAM für Behörden mit Hilfe der Daten ausführen, die im Datenmanagementsystem (DAMAS) hinterlegt sind. In diesem Sinne stellt das

IAM für Behörden in der Zero-Trust-Architektur gemeinsam mit dem Pflegesystem DAMAS einen Policy Decision Point dar.

Ebenso wirkt das IAM für Behörden als Policy Enforcement Point und schließt einen DC kurzfristig vom Daten-Austausch aus, falls dieser beispielsweise im Rahmen des zentralen Monitorings durch verdächtige Aktivitäten aufgefallen ist. Dieser Ausschluss wird erreicht, indem das Zugriffstoken nicht ausgestellt wird, was einen zeitnahen, schadenbegrenzenden und dennoch leicht wieder aufzuhebenden Reaktionsmechanismus darstellt.

Die folgenden Anforderungen sind vom IAM für Behörden umzusetzen. Sie sind teilweise nur im Zusammenspiel mit Systemen außerhalb des Verantwortungsbereichs des NOOTS erfüllbar. Das NOOTS muss in diesen Fällen die Umsetzung unterstützen und ermöglichen. Gleichzeitig stellt dies keine abschließende Liste an Anforderungen an die entsprechenden Systeme außerhalb des NOOTS dar.

5.2.1 Identifizierung und Authentifizierung

- [Z.2.1] Das IAM für Behörden MUSS von den SAK der DC zuverlässig identifiziert und authentifiziert werden können.
- [Z.2.2] Die privaten Schlüssel des IAM für Behörden MÜSSEN auf Hardware Security Modules erzeugt und gespeichert werden. Für die Verwaltung des kryptographischen Materials MUSS mindestens das Security Level 2 gemäß der Key Lifecycle Security Requirements (18) eingehalten werden.
- [Z.2.3] Das IAM für Behörden MUSS registrierte Data Consumer des NOOTS und ihre SAK zuverlässig identifizieren, authentifizieren und ihnen ein Zugriffstoken als Nachweis über ihre Teilnahmeberechtigung ausstellen. Dieses Zugriffstoken MUSS zeitlich befristet und mit einer Nonce versehen sein sowie vom IAM für Behörden gesiegelt werden.
- [Z.2.4] Bei jeder Kommunikation zwischen SAK-DC und dem IAM für Behörden MUSS eine mTLS-Verschlüsselung verwendet werden, die den Anforderungen der TR-02102-2 (19) genügt.
- [Z.2.5] Es MUSS sichergestellt werden, dass nur DC an einem Nachweisaustausch über NOOTS teilnehmen können, die vor Beginn des Nachweisaustausches dem IAM für Behörden bekannt sind.
- [Z.2.6] Das IAM für Behörden oder der SAK des IAM für Behörden oder das Application-Level-Gateway (ALG) des IAM für Behörden MUSS prüfen, dass das Anfragetoken des DC von dem ihm zugeordneten Siegelzertifikat gesiegelt wurde, dass der entsprechende Zeitstempel nicht abgelaufen ist und die Nonce der Anfrage noch nicht behandelt wurde.
- [Z.2.7] Es DARF NICHT möglich sein, mit veralteten Versionen eines SAK über die Übergangszeit hinaus am IAM für Behörden ein Token über die Teilnahmeberechtigung als NOOTS-Teilnehmer zu erlangen. Die Übergangszeit MUSS entsprechend der Kritikalität des Updates gewählt sein und MUSS entsprechend an alle NOOTS-Teilnehmer kommuniziert werden.
- [Z.2.8] Bei einer von einem SAK eingehenden Anfrage an das IAM für Behörden MUSS dieses (beispielsweise über die Siegelung der Anfrage) die betriebsverantwortliche Stelle des SAK ermitteln und überprüfen, dass diese existent und aktuell zur Kommunikation über das NOOTS berechtigt ist.
- [Z.2.9] Das IAM für Behörden MUSS den anfragenden DC authentifizieren und überprüfen, dass dieser registriert und aktuell zur Kommunikation über das NOOTS berechtigt ist. Ferner MUSS das IAM für Behörden sicherstellen, dass der DC und die gemäß [Z.2.8] ermittelte betriebsverantwortliche Stelle zusammengehören.
- [Z.2.10] Bei einer eingehenden Anfrage an das IAM für Behörden MUSS dieses die fachverantwortliche Stelle der Anfrage ermitteln und überprüfen, dass diese registriert ist und aktuell zur Teilnahme am NOOTS berechtigt ist.
- [Z.2.11] Jeder DC MUSS über eine für die Anbindung an NOOTS dedizierte digitale Signatur (5) eindeutig identifizierbar sein.
- [Z.2.12] Das IAM für Behörden MUSS die verwendeten Noncen bis zur Ablaufzeit der dazugehörigen Zeitstempel speichern, um Replay-Angriffe zu verhindern.

- [Z.2.13] Zur Registrierung neuer DCs und DPs im NOOTS sowie zur Pflege und Aktualisierung derer Daten SOLLTEN Pflegesysteme verwendet werden, die vom IAM für Behörden getrennt sind, um die Angriffsfläche auf dieses zentrale Authentifizierungssystem zu minimieren.
- [Z.2.14] Das IAM für Behörden MUSS in regelmäßigen Abständen mit aktuellen Daten der registrierten DCs versorgt werden. Die Abstände sind geeignet festzulegen, um sicherzustellen, dass neu hinzugekommene DC zeitnah verwendet werden können sowie für nicht mehr verwendete DC zeitnah keine Zugriffstoken mehr ausgestellt werden können.
- [Z.2.15] Im Falle einer Sperrung eines DCs durch die zentrale Monitoring-Komponente des NOOTS MUSS das IAMfB unverzüglich mit aktuellen Berechtigungsinformationen der registrierten DCs versorgt werden.
- [Z.2.16] Es MUSS die Möglichkeit geben, dass das IAM für Behörden in Notfällen kurzfristig einem bestimmten DC keine weiteren Zugriffstoken ausstellt, wenn dieser DC sich auffällig verhält und dies über das Monitoring oder andere Wege bekannt geworden ist.
- [Z.2.17] Ist eine Überprüfung der Teilnahmeberechtigung oder Identifizierung oder Authentifizierung fehlgeschlagen, DARF KEIN Zugriffstoken ausgestellt werden. Der Vorgang MUSS protokolliert werden und der Protokolleintrag der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]-[A.2.8]). Es MUSS eine Fehlermeldung an den Kommunikationspartner gesendet werden, dessen Teilnahmeberechtigung oder Identität oder Authentizität nicht bestätigt werden konnte. Die Fehlermeldung DARF KEINE Informationen enthalten, die ein Herantasten an eine unberechtigte Teilnahme am NOOTS vereinfachen.
- [Z.2.18] Auch jedes erfolgreiche Ausstellen eines Zugriffstokens MUSS unter Angabe des verwendeten SAK sowie der fach- und betriebsverantwortlichen Stelle protokolliert werden und dieses Protokoll ebenfalls der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]-[A.2.8]).

5.3 Registerdatennavigation

Die Registerdatennavigation (RDN) dient dem Auffinden des zuständigen DP für einen gegebenen Nachweisabruf. Sie wird vom SAK des DC aufgerufen, nachdem sich dieser bereits am IAM für Behörden eine Teilnahmeberechtigung in Form eines Zugriffstokens für das NOOTS ausstellen lassen hat. Hierbei erfragt der SAK des DC bei der RDN den zuständigen Data Provider für einen angefragten Nachweistyp. Die RDN beantwortet diese Anfrage mit dem Zuständigkeitstoken, in dem u.a. die Information über Name und ID des zuständigen Data Providers gesiegelt vorliegen. Je nach Rückmeldung der RDN muss der SAK des DC daraufhin die IDNr oder die beWiNr. zum angeforderten Nachweis ermitteln, wenn das zuständige Register diese Information benötigt. In jedem Fall muss der SAK des DC die Vermittlungsstelle (VS) anrufen und erst mit dem von der VS ausgestellten Token zur abstrakten Abrufberechtigung kann der SAK des DC bei der RDN die Verbindungsdaten des benötigten Data Providers abrufen. Die RDN beantwortet diese Anfrage mit den in dem Verbindungstoken gesiegelten Verbindungsdaten. Die für diese Funktionen notwendige Datengrundlage bezieht die RDN aus dem DAMAS, das auch das IAM für Behörden und die VS speist.

Indem die RDN überprüft, dass eine an sie gestellte Anfrage vorschriftsgemäß erfolgt, übernimmt sie in der Zero-Trust-Architektur die Rolle eines Policy Decision Points. Im Falle einer Abschaltung einzelner Komponenten, beispielsweise aufgrund von Auffälligkeiten im Monitoring, übernimmt die RDN auch die Rolle eines Policy Enforcement Points, indem sie die entsprechenden Verbindungsdaten zurückhält.

5.3.1 Anforderungen an die Registerdatennavigation

- [Z.3.1] Die RDN MUSS von allen anderen Komponenten des NOOTS sowie von DCs und DPs und ihren SAK zuverlässig identifiziert und authentifiziert werden können.
- [Z.3.2] Die privaten Schlüssel der RDN MÜSSEN auf Hardware Security Modules erzeugt und gespeichert werden. Für die Verwaltung des kryptographischen Materials MUSS mindestens das Security Level 2 gemäß der Key Lifecycle Security Requirements (14) eingehalten werden.
- [Z.3.3] Die RDN MUSS nachprüfen, dass der anfragende SAK des DC ein Zugriffstoken übermittelt hat, das zeitlich gültig ist und das ein verifizierbares Siegel besitzt.

- [Z.3.4] Falls die Verifikation der Abfrageberechtigung des anfragenden Systems gemäß [Z.3.3] negativ ausfällt, DARF die RDN KEINE Verbindungsparameter zurückliefern. Sie MUSS eine Fehlermeldung zurücksenden. Die Fehlermeldung DARF KEINE Informationen enthalten, die ein Herantasten an eine unberechtigte Teilnahme am NOOTS vereinfachen.
- [Z.3.5] Die RDN DARF NUR Einblick in den angefragten Nachweistyp und diejenigen darüber hinausgehenden Daten, die zur Bestimmung des zuständigen Data Providers unerlässlich sind (wie beispielsweise die Postleitzahl beim Abruf eines dezentral vorliegenden Nachweises) der Nachweisanfrage des DC erhalten.
- [Z.3.6] Im Falle einer erfolgreichen Verifikation der Abfrageberechtigung des anfragenden Systems gemäß [Z.3.3] sowie erfolgreicher Ermittlung des gesuchten DP und dessen Verbindungsparameter MUSS die RDN die zurückzuliefernden Informationen siegeln.
- [Z.3.7] Bei der Kommunikation zwischen dem SAK des DC und der RDN MUSS eine mTLS-Verschlüsselung gemäß TR-02102-2 verwendet werden.
- [Z.3.8] Falls die Abfrageberechtigung gemäß [Z.3.3] verifiziert werden konnte, aber der gesuchte DP bzw. dessen Verbindungsparameter nicht geliefert werden können, MUSS die RDN eine Fehlermeldung zurücksenden.
- [Z.3.9] Zur Hinterlegung der Zuständigkeiten und Verbindungsparameter der DPs im NOOTS SOLLTE ein Pflegesystem verwendet werden, das von der RDN getrennt ist.
- [Z.3.10] Die RDN MUSS in regelmäßigen Abständen mit aktuellen Daten der registrierten DP versorgt werden. Die Abstände sind geeignet festzulegen, um sicherzustellen, dass neu hinzugekommene DP zeitnah verwendet werden können sowie dass für nicht mehr verwendete DP zeitnah keine Zuständigkeiten und Verbindungsparameter mehr herausgegeben werden.
- [Z.3.11] Im Falle einer Sperrung eines DPs durch die zentrale Monitoring-Komponente des NOOTS MUSS die RDN unverzüglich mit aktuellen Berechtigungsinformationen der registrierten DPs versorgt werden.
- [Z.3.12] Im Falle einer vom Monitoring detektierten Auffälligkeit bei einem der DP MUSS die RDN das notfallmäßige kurzfristige Sperren des betroffenen DP im NOOTS unterstützen, indem sie keine Daten über diesen DP liefert.
- [Z.3.13] Die RDN MUSS sowohl erfolgreiche als auch abgelehnte Anfragen und Anfragen, bei denen die gesuchten Zuständigkeiten oder Verbindungsparameter nicht ermittelt werden konnten, protokollieren und diese Protokolle der zentralen Monitoring-Komponente übermitteln (vgl. [A.2.6]-[A.2.8]).

5.4 Vermittlungsstelle: Abstrakte Berechtigungsprüfung

Die Vermittlungsstelle (VS) ist eine zentrale Komponente des NOOTS, die eine abstrakte Berechtigungsprüfung durchführt und protokolliert. Gesetzlich vorgeschrieben ist sie für Nachweisabrufe unter Verwendung der IDNr. Sie wird im NOOTS im Sinne einer umfassenden Absicherung für alle Nachweisabrufe – nicht nur solche unter Verwendung der IDNr - eingesetzt und prüft im Zusammenspiel mit dem IAM für Behörden und dem SAK des DP, dass der anfragende DC die grundsätzliche Berechtigung besitzt, bei dem angefragten DP den angefragten Nachweistyp abzurufen. In diesem Sinne stellt sie einen weiteren Policy Decision Point in der Zero-Trust-Architektur dar. Bei erfolgreicher Überprüfung dieser abstrakten Berechtigung zum Nachweisabruf sendet die VS zur Bestätigung das sog. Abruftoken zurück. Die konkrete Berechtigung der abrufenden natürlichen bzw. juristischen Person zum Abruf eines bestimmten Nachweises wird hingegen nicht von der VS geprüft, sondern liegt im Aufgabenbereich des DP.

5.4.1 Anforderungen an die abstrakte Berechtigungsprüfung

- [Z.4.1] Die Vermittlungsstelle (VS) als die zentrale Komponente des NOOTS zur Autorisierung von Nachweisabrufen MUSS von allen anderen Komponenten des NOOTS sowie von DCs und DPs und ihren SAK zuverlässig identifiziert und authentifiziert werden können.
- [Z.4.2] Die privaten Schlüssel der Vermittlungsstelle des NOOTS MÜSSEN auf Hardware Security Modules erzeugt und gespeichert werden. Für die Verwaltung des kryptographischen Materials MUSS

mindestens das Security Level 2 gemäß der Key Lifecycle Security Requirements (18) eingehalten werden.

- [Z.4.3] Vor jedem Nachweisabruf unter Verwendung der IDNr MUSS eine abstrakte Berechtigungsprüfung unter Einbeziehung der VS gemäß IDNrG §7 durchgeführt werden. Hierbei DARF die VS NICHT Einblick in die Inhaltsdaten der Nachweisanfrage erhalten.
- [Z.4.4] Vor jedem Nachweisabruf ohne Verwendung der IDNr SOLLTE eine abstrakte Berechtigungsprüfung durchgeführt werden. Hierzu MUSS die VS auf Grundlage des angefragten Nachweistyps prüfen, ob der anfragende DC zum Datenabruf beim angefragten DP berechtigt ist. Hierbei DARF die VS NICHT Einblick in die Inhaltsdaten der Nachweisanfrage erhalten.
- [Z.4.5] Die VS MUSS die Teilnahmeberechtigung des anfragenden DC nachprüfen. Das entsprechende Zugriffstoken MUSS bezüglich Zeitstempel und Siegelung des IAM für Behörden geprüft werden.
- [Z.4.6] Die VS MUSS das vom SAK des DC übermittelte Zuständigkeitstoken bezüglich Zeitstempel und Siegelung der RDN überprüfen.
- [Z.4.7] Falls das Zugriffstoken des anfragenden DC oder das Zuständigkeitstoken nicht gültig ist, DARF die VS KEINE Berechtigungsprüfung durchführen und kein entsprechendes Abruftoken zurücksenden. Sie MUSS eine Fehlermeldung zurücksenden. Die Fehlermeldung DARF KEINE Informationen enthalten, die ein Herantasten an eine unberechtigte Teilnahme am NOOTS vereinfachen.
- [Z.4.8] Zur Hinterlegung der Abrufberechtigungen der DCs bei den jeweiligen DPs auf Grundlage des angefragten Nachweistyps SOLLTE ein Pflegesystem verwendet werden, das von der VS getrennt gepflegt wird.
- [Z.4.9] Die VS MUSS in regelmäßigen Abständen mit aktuellen Berechtigungsinformationen der registrierten DCs und DPs versorgt werden. Die Abstände sind geeignet festzulegen, um sicherzustellen, dass bei neu hinzugekommenen Berechtigungen zeitnah ein Nachweisabruf über das NOOTS ermöglicht wird sowie dass auf Grundlage von veralteten Berechtigungsdaten zeitnah keine Abruftoken der VS mehr ausgestellt werden.
- [Z.4.10] Im Falle einer Sperrung eines DCs oder DPs durch die zentrale Monitoring-Komponente des NOOTS MUSS die VS unverzüglich mit aktuellen Berechtigungsinformationen der registrierten DCs und DPs versorgt werden.
- [Z.4.11] Bei erfolgreicher Verifizierung der Teilnahmeberechtigung des anfragenden Systems und erfolgreicher abstrakter Berechtigungsprüfung MUSS die VS ein Abruftoken ausstellen und dem SAK des anfragenden DC zur Verfügung stellen. Dieses Abruftoken muss zeitlich befristet gültig sein, den Hashwert der Nachweisabfrage enthalten und von der VS gesiegelt werden. Der Vorgang MUSS protokolliert werden und der Protokolleintrag der zentralen Monitoring-Komponente des NOOTS zur Verfügung gestellt werden (vgl. [A.2.6]-[A.2.8]).
- [Z.4.12] Bei der Kommunikation zwischen dem SAK des DC und der VS MUSS eine mTLS-Verschlüsselung gemäß TR-02102-2 verwendet werden.
- [Z.4.13] Schlägt die abstrakte Berechtigungsprüfung fehl, DARF KEIN Abruftoken ausgestellt werden. Der Vorgang MUSS protokolliert werden und der Protokolleintrag der zentralen Monitoring-Komponente zur Auswertung zur Verfügung gestellt werden (vgl. [A.2.6]-[A.2.8]). Es MUSS eine Fehlermeldung an den SAK des anfragenden DC gesendet werden. Diese Fehlermeldung DARF KEINE Rückschlüsse auf die Gründe für die Ablehnung zulassen, um ein Herantasten an zulässige Kommunikationspartner zu erschweren.

5.5 Monitoring

Auf Basis der Protokollierung durch die Komponenten des NOOTS (vgl. [A.2.6]-[A.2.8]) ist es notwendig, eine aktive Detektion möglicher Angriffe durchzuführen. Dazu dient das Monitoring aktueller potentiell sicherheitsrelevanter Ereignisse. Da eine abschließende Klärung über die von einer zentralen Monitoring-Komponente des NOOTS abgedeckten technischen Systeme zum Zeitpunkt der Erstellung dieses Dokuments noch aussteht, wird eine Erweiterung/Präzisierung der Anforderungen in einer zukünftigen Version angestrebt.

Es sind die folgenden Anforderungen umzusetzen:

- [Z.5.1] Anforderung DER.1.A17 „Automatische Reaktion auf sicherheitsrelevante Ereignisse“ (einschließlich der dort erwähnten SOLLTE-Anforderungen) des IT-Grundschutz-Kompendiums oder eine andere Maßnahme mit ähnlicher Sicherheitswirkung MUSS umgesetzt werden.
- [Z.5.2] Es MÜSSEN Meldekettens für die Meldung von Sicherheitsvorfällen etabliert werden.
- [Z.5.3] Es MUSS einen Prozess zur gleichzeitigen Notabschaltung aller zentralen NOOTS Komponenten geben.
- [Z.5.4] Es MUSS eine zentrale Monitoring-Komponente etabliert werden, die die von den verschiedenen zentralen NOOTS-Komponenten und SAK erzeugten und bereitgestellten Protokolle auswertet und bei Auffälligkeiten automatisiert reagiert. Diese Reaktion MUSS darin bestehen, dass vorher festgelegte Maßnahmen zur Abwehr und Mitigation von Schäden eingeleitet werden.
- [Z.5.5] Insbesondere SOLLTE ein Prozess etabliert werden, der es
- a) dem IAM für Behörden erlaubt, bei Auffälligkeiten (wie beispielsweise einer Häufung abgelehnter Anfragen eines DC innerhalb einer kurzen Zeitspanne), die einen bestimmten DC betreffen, diesen automatisiert von der weiteren Teilnahme am NOOTS auszuschließen, indem mit sofortiger Wirkung keine Zugriffstoken mehr ausgestellt werden;
 - b) der RDN erlaubt, bei Auffälligkeiten, die einen bestimmten DP betreffen, diesen automatisiert von der weiteren Teilnahme am NOOTS auszuschließen, indem mit sofortiger Wirkung das entsprechende Zuständigkeitstoken nicht mehr zur Verfügung gestellt wird.

Diese Maßnahme MUSS einen vorher definierten Prozess auslösen, bei dem eine manuelle Klärung und gegebenenfalls eine Aufhebung der Sperre oder eine Anordnung weiterer Maßnahmen erfolgt.

6 Sichere Anschlussknoten

Zur Kommunikation im NOOTS werden von der betriebsverantwortlichen Stelle des NOOTS Sichere Anschlussknoten (SAK) entwickelt und an alle anzubindenden Stellen verteilt. Zur Anbindung der DC und DP an das NOOTS sind diese SAK verpflichtend einzusetzen. Die Verantwortung für den Betrieb der SAK liegt bei den betriebsverantwortlichen Stellen der DC und DP und nicht bei der betriebsverantwortlichen Stelle des NOOTS, also dem BVA. IT-Sicherheitsanforderungen an die fachverantwortlichen und betriebsverantwortlichen Stellen der DC und DP in Bezug auf den Einsatz der SAK werden separat in der TR-03190 ("IT-Sicherheitsanforderungen für die Anbindung an das NOOTS") adressiert. Das vorliegende Kapitel befasst sich mit den IT-Sicherheitsanforderungen, die von der betriebsverantwortlichen Stelle des NOOTS bei der Entwicklung und Bereitstellung der SAK beachtet werden müssen sowie mit den Anforderungen, die an die SAK zu stellen sind.

Der SAK des DC nimmt im Rahmen der NOOTS-Sicherheitsarchitektur eine eher untergeordnete Rolle ein. Er dient vorrangig dem DC als Hilfsmittel, das alle Schritte des Nachweisabrufprozesses inklusive Anforderung des Zugriffstokens über die Teilnahmberechtigung am NOOTS beim IAMfB, Ermittlung des zuständigen DP sowie seiner Verbindungsparameter mittels der RDN sowie abstrakter Berechtigungsprüfung mit Hilfe der Vermittlungsstelle initiiert. Des Weiteren übernimmt er im Zusammenspiel mit dem SAK des DP zentrale Aufgaben bei der Ver- und Entschlüsselung von Nachrichten. Nach Empfang des angeforderten Nachweises führt er eine Schemavalidierung durch, um sicherzustellen, dass keine vom erwarteten XNachweis-Nachrichtentyp abweichenden Daten zum DC weitergeleitet werden. Darüber hinaus ist geplant, dass er eine Möglichkeit für die SAK-betreibende Stelle bietet, einen zusätzlichen Virenschanner einzubauen, um den DC über eine reine Schemavalidierung hinaus vor Malware zu schützen.

Dem SAK des DP kommt im Rahmen der Sicherheitsarchitektur von NOOTS eine zentrale Rolle zu. Er wirkt als PEP (Policy Enforcement Point) der zugrundeliegenden Zero Trust Architektur: Während beispielsweise das IAM für Behörden als Policy Decision Point über die Teilnahmberechtigung einer nachweisanfragenden Komponente entscheidet, setzt der SAK des DP diese Entscheidung durch, indem er die Nachweisanfrage nur bei Vorliegen eines vom IAM für Behörden gesiegelten und gültigen Zugriffstokens an den DP weiterleitet. Dennoch entbindet das den DP nicht von seiner Pflicht, sich selbst von der Rechtmäßigkeit der Anfrage zu überzeugen, weswegen der SAK des DP alle zu prüfenden Token zusätzlich an den DP weiterleitet.

Zusätzlich zu den Anforderungen, die die SAK NOOTS-seitig erfüllen müssen, um einen reibungslosen, regelkonformen und sicheren Nachweisabruf zu ermöglichen, werden hier Anforderungen aufgelistet, die im Zusammenspiel zwischen SAK und DC bzw. DP vom SAK zu erfüllen sind. Die entsprechenden Anforderungen, die in diesem Zusammenhang von den DCs und DPs selbst zu erfüllen sind, finden sich in der TR-03190, „Anschlussbedingungen an das NOOTS“.

6.1 Build-, Release- und Deploymentmanagement

[SAK.1.1] Es MUSS ein Build-, Release- und Deploymentmanagement umgesetzt werden, welches Prozesse zur Erstellung, Prüfung und Verteilung der Builds und Releases sowie zum Deployment enthält.

[SAK.1.2] Der Hersteller bzw. Entwickler der SAK MUSS eine zentrale und vollständige Liste von Abhängigkeiten durch externe Software, Bibliotheken und Frameworks führen. Es SOLLTE eine Software Bill of Materials (SBOM), wie in der BSI TR-03183-2 „Cyber-Resilienz-Anforderungen an Hersteller und Produkte“ (15) gefordert, erstellt und geführt werden.

[SAK.1.3] Falls Drittsoftware verwendet wird, MUSS Software aus vertrauenswürdigen Quellen verwendet werden. Nicht verwendete Funktionen SOLLTEN deaktiviert werden.

[SAK.1.4] Eingesetzte (Dritt-) Software MUSS in einer Version verwendet werden, die mit Sicherheitsupdates versorgt wird. Wenn für die Anwendung relevante Schwachstellen in verwendeter Software bekannt werden, MÜSSEN die zugehörigen Sicherheitsupdates kurzfristig eingespielt werden. Die

Umsetzungszeit MUSS der Kritikalität und Ausnutzbarkeit der Schwachstelle entsprechend angemessen gewählt werden. Software, die nicht länger vom Hersteller oder Entwickler gewartet wird, DARF NICHT verwendet werden.

- [SAK.1.5] Alle erstellten Softwarepakete und Updates MÜSSEN vor der Auslieferung mindestens fortgeschritten signiert werden.
- [SAK.1.6] Versionierungen SOLLTEN verständlich und nachvollziehbar gewählt werden. Release Notes MÜSSEN erstellt werden. Insbesondere SOLLTEN Informationen zu sicherheitskritischen Updates und Supportdauer einer Version enthalten sein.
- [SAK.1.7] Es SOLLTE durch technische Maßnahmen sichergestellt sein, dass alle NOOTS-Teilnehmer eine aktuelle Softwareversion der SAK verwenden. Es SOLLTE NICHT möglich sein, mit veralteten Versionen über die Übergangszeit hinaus am IAM für Behörden ein Token über die Teilnahmeberechtigung als NOOTS-Teilnehmer zu erlangen. Die Übergangszeit MUSS entsprechend der Kritikalität des Updates gewählt sein und MUSS an alle NOOTS-Teilnehmer kommuniziert werden.
- [SAK.1.8] Der SAK SOLLTE als Application-Level-Gateway (ALG) konzipiert sein, damit er in der demilitarisierten Zone (DMZ) der betriebsverantwortlichen Stelle des dazugehörigen DC bzw. DP als Teil der PAP-Struktur zwischen zwei Firewalls eingesetzt werden kann. Es MUSS für die betriebsverantwortliche Stelle auch möglich sein, den SAK im Sinne einer erhöhten Absicherung hinter einer PAP-Struktur oder als Erweiterung der PAP-Struktur zu betreiben.
- [SAK.1.9] Die Verbindungsdaten der zentralen NOOTS-Komponenten MÜSSEN im SAK des DC fest hinterlegt sein. Alle SAK MÜSSEN die Zertifikate der zentralen NOOTS-Komponenten (IAM für Behörden, RDN, VS, IDM für Personen, zentrale Monitoring-Komponente) über einen im Auftrag des BVA betriebenen Webserver beziehen und aktuell halten. Die zur Verifikation der genutzten Zertifikate notwendigen Wurzelzertifikate MÜSSEN bereits bei Auslieferung des SAK enthalten sein.

6.2 Kryptographische Anforderungen

Folgende Anforderungen gelten für die Verschlüsselung der Nachrichten, an deren Versand, Empfang oder Transport Sichere Anschlussknoten beteiligt sind.

- [SAK.2.1] Es DÜRFEN NUR Protokolle eingesetzt werden, die kryptographische Algorithmen verwenden, welche gemäß der TR-03116-4 (20) zulässig sind und gemäß TR-02102-1 (5) bzw. TR-02102-2 (19) dem Stand der Technik entsprechen. Kryptographische Verfahren werden für folgende Zwecke eingesetzt:
- [SAK.2.2] Die Sicherstellung der Vertraulichkeit auf Inhaltsdatenebene (Ende-zu-Ende-Verschlüsselung),
- [SAK.2.3] die Sicherstellung der Vertraulichkeit auf Transportebene (Transportverschlüsselung),
- [SAK.2.4] die Sicherstellung der Integrität und Authentizität auf Inhaltsdatenebene (Ende-zu-Ende-Verifikation) sowie
- [SAK.2.5] die Sicherstellung der Integrität und Authentizität auf Transportebene (Transportverifikation).
- [SAK.2.6] Es MUSS eine Ende-zu-Ende-Inhaltsverschlüsselung für die Verschlüsselung der Fachdaten zwischen dem SAK des DC und dem SAK des DP sowie bei der Antwort zwischen dem SAK des DP und dem SAK des DC eingesetzt werden. Kommen bei der Übermittlung der Fachdaten weitere zwischengeschaltete Systeme zwischen den SAK von DC und DP zum Einsatz (beispielsweise ALG, die in der demilitarisierten Zone der betriebsverantwortlichen Stelle des NOOTS-Teilnehmers betrieben werden), so MÜSSEN alle zwischengeschalteten Systeme ihren Dienst ohne Kenntnis der Fachdaten erfüllen können und DÜRFEN NICHT in die Lage versetzt werden, Fachdaten im Klartext einzusehen.
- [SAK.2.7] Es MUSS eine TLS-Verschlüsselung gemäß TR-02102-2 (19) für die Verschlüsselung der Transportnachricht jeweils zwischen zwei Systemen eingesetzt werden. Diese Transportverschlüsselung DARF an Systemen aufgebrochen werden, die zwischen den SAK von DC und DP liegen, und MUSS für den weiteren Transport der Nachricht wieder hergestellt werden. Nimmt der SAK die Rolle des versendenden Systems bei der Kommunikation ein, so MUSS mTLS verwendet werden.

6.3 Nachrichtenvalidierung

In der öffentlichen Verwaltung werden verschiedene Standards zur Darstellung von Daten in maschinenlesbaren Formaten verwendet. Die Einhaltung dieser standardisierten Formate ist sehr wichtig, um eine fehlerfreie Datenverarbeitung durch andere Systeme sicherzustellen. Daher sind folgende Anforderungen an die Nachrichtenvalidierung zu erfüllen:

- [SAK.3.1] Alle eingesetzten Standards zur Übermittlung MÜSSEN eine Beschreibung des Nachrichtenaufbaus enthalten (z.B. ein Schema in einer konkreten Ausprägung, ggf. mit Versionsnummer), die den Aufbau einer korrekten Nachricht sowie die hierfür zulässigen Datentypen beschreibt.
- [SAK.3.2] Jedes eine Fachnachricht empfangende System MUSS vor der semantischen Auswertung der Fachnachricht anhand der Beschreibung des Nachrichtenaufbaus eine Validierung der Korrektheit des Nachrichtenaufbaus durchführen.
- [SAK.3.3] Vor der Extraktion und Entschlüsselung der gemäß [SAK.2.6] gesicherten Fachnachricht MUSS die für deren Transport verwendete Transportnachricht anhand der Beschreibung ihres Nachrichtenaufbaues validiert werden.
- [SAK.3.4] Falls Fachdaten mit Hilfe eines Transportprotokolls übertragen werden, das die Fachdaten mit zusätzlichen Metadaten anreichert, so SOLLTEN alle an dem Transport beteiligten Systeme vor dem Verarbeiten der Metadaten der Transportnachricht oder der Extraktion der Fachdaten die Transportnachricht anhand der Beschreibung des Nachrichtenaufbaus des verwendeten Transportprotokolls validieren.
- [SAK.3.5] Bei fehlgeschlagener Validierung MÜSSEN die Nachrichten abgelehnt werden, ein manueller Reparaturprozess ist nicht zulässig.
- [SAK.3.6] Fehlerhafte Nachrichten DÜRFEN NICHT außerhalb der Fehleranalyse gespeichert werden. Sie DÜRFEN NICHT ohne zusätzliche Sicherungsmaßnahmen geloggt werden.

6.4 Fehlerbehandlung

- [SAK.4.1] Stellt eine der beteiligten Parteien fest, dass eine der MUSS-Anforderungen dieser Technischen Richtlinie im Rahmen der Übermittlung einer Nachricht verletzt wurde, so MUSS die Nachricht abgewiesen werden und DARF NICHT weiterverarbeitet werden. Dem sendenden System der Nachricht MUSS eine Fehlermeldung zugeschickt werden.
- [SAK.4.2] Die Fehlermeldungen DÜRFEN NICHT Rückschlüsse auf oder Einblicke in die Funktionsweise des Kommunikationspartners bieten. Es MÜSSEN vordefinierte Fehlermeldungen und formal prüfbare Fehlercodes für die Rückmeldung an anfragende Systeme verwendet werden. Die verwendeten Fehlermeldungen SOLLTEN entsprechend der Vorschläge für Status Code Reason Phrases des RFC 9110 (21) ausgestaltet werden.
- [SAK.4.3] Die Fehlermeldungen DÜRFEN NICHT personenbezogene Daten enthalten.
- [SAK.4.4] Nachrichten, die einem an der Datenübermittlung beteiligten System vorliegen, DÜRFEN NICHT länger als notwendig aufbewahrt werden. Schlägt die Zustellung fehl, MÜSSEN sie gelöscht werden.

6.5 Sicherer Anschlussknoten für Data Consumer

- [SAK.5.1] Der SAK des DC MUSS die Server-TLS-Zertifikate der zentralen NOOTS-Komponenten und der SAK der DP's zu Beginn jeder Kommunikation auf Gültigkeit prüfen. Schlägt die Prüfung fehl, so MUSS die Kommunikation abgebrochen und der Vorgang protokolliert werden.
- [SAK.5.2] Falls der SAK des DC kein zeitlich gültiges Zugriffstoken für den anfragenden DC besitzt, MUSS der SAK des DC sich zu Beginn eines Nachweisabrufs gegenüber der zentralen NOOTS-Komponente IAM für Behörden authentifizieren und zusätzlich die Authentifizierungsinformationen des DC, für den er tätig ist, weitergeben.

- [SAK.5.3] Der SAK des DC MUSS für jede Nachweisabfrage den zuständigen DP und dessen Verbindungsparameter bei der RDN ermitteln. Er MUSS das Siegel der RDN auf den so erhaltenen Verbindungsparametern auf Gültigkeit prüfen und verifizieren.
- [SAK.5.4] Der SAK des DC MUSS für jede Nachweisabfrage eine abstrakte Berechtigungsprüfung durch die VS anstoßen.
- [SAK.5.5] Der SAK des DC MUSS vor der Verschlüsselung und Weiterleitung einer Nachricht durch Schemavalidierung prüfen, dass diese dem vorgegebenen XNachweis-Aufbau entspricht.
- [SAK.5.6] Der SAK des DC MUSS für jede Nachweisabfrage die Inhaltsdaten der Nachweisabfrage für den SAK des DP verschlüsseln. Diese Inhaltsdatenverschlüsselung MUSS als Ende-zu-Ende-Verschlüsselung wirken, die nur für den SAK des DP entschlüsselbar ist. Die verschlüsselten Inhaltsdaten MÜSSEN zusammen mit dem Hashwert des Zugriffstoken durch den SAK des DC gesiegelt werden.
- [SAK.5.7] Der SAK des DC MUSS das Zugriffstoken des IAM für Behörden, das Zuständigkeitstoken der Registerdatenavigation und das Abruftoken der Vermittlungsstelle zusammen mit den verschlüsselten Inhalten der Nachweisanfrage und ggf. dem Token vom IDM für Personen, das die IDNr enthält, und ggf. einem Token, das die Authentifizierung der anfragenden Person bestätigt, an den SAK des von der RDN ermittelten DP senden. Das Versenden der Nachweisanfrage an den SAK des DP muss protokolliert werden und das Protokoll der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]-[A.2.8]).
- [SAK.5.8] Bei eingehenden angefragten Nachweisen MUSS der SAK des DC nach Entfernen der Transportverschlüsselung das Siegel des SAK des DP verifizieren und die Gültigkeit des zugehörigen Zertifikats überprüfen. Der SAK des DC MUSS überprüfen, dass die in diesem Siegel enthaltenen, den SAK des DP identifizierenden Informationen mit den von der RDN erhaltenen Informationen über den angefragten SAK des DP übereinstimmen. Falls diese Prüfschritte erfolgreich sind, MUSS der SAK des DC die Inhalte der Nachricht entschlüsseln. Andernfalls DARF er sie NICHT entschlüsseln.
- [SAK.5.9] Im Falle einer Entschlüsselung der Inhalte gemäß [SAK.5.8] MUSS der SAK des DC eine Schemavalidierung der Inhalte anhand des zu erwartenden Nachrichtenaufbaus durchführen. Schlägt diese fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.5.10] Alle oben beschriebenen Fehlerfälle MÜSSEN protokolliert und die Protokolldaten der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]-[A.2.8]). Eine Fehlermeldung MUSS an den Kommunikationspartner versandt werden. Sie DARF KEINE Rückschlüsse auf das verwendete Verifikationsschema zulassen, um ein Herantasten unberechtigter Nutzer an eine korrekte Nachricht zu erschweren.
- [SAK.5.11] Alle erfolgreich durchgeführten Nachweisabrufe MÜSSEN protokolliert werden und die Protokolldaten der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]-[A.2.8]).
- [SAK.5.12] Der SAK des DC MUSS eine Möglichkeit bieten, einen Virens Scanner einzubinden.

6.6 Sicherer Anschlussknoten für Data Provider

- [SAK.6.1] Der SAK des DP MUSS den oder die DP(s), für den oder die er betrieben wird, vor jeder Interaktion mit ihnen sicher identifizieren und authentifizieren.
- [SAK.6.2] Der SAK des DP MUSS zu Beginn jeder Interaktion die Gültigkeit des Client-TLS-Zertifikats des anfragenden SAK des DCs überprüfen.
- [SAK.6.3] Bei jedem Nachweisabruf MUSS der SAK des DP verifizieren, dass dieser von einem NOOTS-Teilnehmer stammt. Er MUSS die Teilnahmerechtigung dieses NOOTS-Teilnehmers über das mitgelieferte, vom IAM für Behörden gesiegelte Zugriffstoken nachprüfen. Hierbei MÜSSEN Siegelung und Zeitstempel geprüft werden. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.6.4] Bei jedem Nachweisabruf MUSS der SAK des DP das von der RDN ausgestellte Zuständigkeitstoken nachprüfen. Hierbei MÜSSEN Siegelung und Zeitstempel geprüft werden.
- [SAK.6.5] Bei Nachweisabrufen unter Verwendung der IDNr MUSS der SAK des DP das entsprechende, beigefügte Token des IDM für Personen nachprüfen bezüglich Siegelung und Zeitstempel. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.

- [SAK.6.6] Der SAK des DP MUSS das Siegel des SAK des DC auf den übersendeten verschlüsselten Inhaltsdaten verifizieren und die Gültigkeit des zugehörigen Zertifikats überprüfen. Der SAK des DP MUSS überprüfen, dass die in diesem Siegel enthaltenen, den SAK des DC identifizierenden Informationen mit den im Zugriffstoken enthaltenen Informationen über den anfragenden SAK des DC übereinstimmen. Zudem MUSS der SAK des DP den Hashwert des Zugriffstoken berechnen und überprüfen, dass dieser mit dem in den gesiegelten Daten hinterlegten Hashwert des Zugriffstoken übereinstimmt. Wenn alle Prüfungen bis zu diesem Punkt keine Auffälligkeiten ergeben haben, MUSS der SAK des DP die Inhalte der Nachricht entschlüsseln. Andernfalls DARF er sie NICHT entschlüsseln.
- [SAK.6.7] Im Falle einer Entschlüsselung der Inhaltsdaten gemäß [SAK.6.6] MUSS der SAK des DP eine Schemavalidierung der entschlüsselten Nachricht durchführen.
- [SAK.6.8] Der SAK des DP MUSS überprüfen, dass die im Datenfeld „Nachweistyp“ des von der VS ausgestellten Abruftoken enthaltene Information zu der entschlüsselten Nachricht passt, dass das Abruftoken von der VS gesiegelt wurde und zeitlich gültig ist und, dass der im Abruftoken hinterlegte Hashwert zu der Nachweisanfrage passt.
- [SAK.6.9] Bei jedem Nachweisabruf, der durch eine natürliche Person angestoßen wurde, MUSS der SAK des DP nachprüfen, dass die Identität der Person durch Authentifizierung sichergestellt ist, sobald die entsprechende Funktionalität nach eIDAS 2.0 verfügbar ist. Hierfür MUSS der SAK des DP nachprüfen, dass das mit gesendete Authentifizierungstoken eine gültige Siegelung von der dafür im NOOTS oder außerhalb des NOOTS zuständigen Stelle aufweist und zeitlich gültig ist. Schlägt die Überprüfung fehl, DARF die Nachricht NICHT weiterverarbeitet werden.
- [SAK.6.10] Ist mindestens eine der genannten Überprüfungen fehlgeschlagen, DARF der SAK des DP die Nachricht nicht weiterverarbeiten. Er MUSS den Vorgang protokollieren und die Protokolldaten der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]–[A.2.8]). Er MUSS eine Fehlermeldung an den Kommunikationspartner senden, die es aber nicht erlauben darf, Rückschlüsse auf die zugrunde liegenden Sicherheitsmechanismen zu ziehen.
- [SAK.6.11] Sind alle Überprüfungen erfolgreich durchgeführt worden, MUSS der SAK des DP alle geprüften Token gemeinsam mit der Nachweisabfrage an den angeschlossenen DP weiterleiten, damit dieser die Überprüfungen im Sinne von Zero Trust wiederholen kann. Der Vorgang MUSS protokolliert werden und die Protokolldaten der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]–[A.2.8]).
- [SAK.6.12] Für den Versand des angefragten Nachweises an den SAK des DC, der die Anfrage gesendet hat, MUSS der SAK des DP die Inhaltsdaten für den SAK des DC verschlüsseln. Hierbei MÜSSEN die Anforderungen der TR-02102-1 erfüllt werden. Die Inhalte MÜSSEN Ende-zu-Ende verschlüsselt bis zum SAK des DC gesendet werden.
- [SAK.6.13] Die Antwortnachricht des SAK des DP DARF NUR an den SAK des DC weitergeleitet werden, der die Anfrage, die damit beantwortet wird, gestellt hat. Das Versenden der Nachweisantwort an den SAK des DC MUSS protokolliert werden und die Protokolldaten der zentralen Monitoring-Komponente übermittelt werden (vgl. [A.2.6]–[A.2.8]).

Literaturverzeichnis

1. Deutscher Bundestag: Datenaustausch zwischen öffentlichen Stellen von Bund und Ländern - NOOTS Staatsvertrag. [Online] 13. Oktober 2025. <https://www.bundestag.de/dokumente/textarchiv/2025/kw26-de-noots-1084816>.
2. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-03172 Portalverbund. [Online] 14. November 2024. <https://www.bsi.bund.de/dok/tr-03172>.
3. Bundesamt für Sicherheit in der Informationstechnik (Hrsg.). *IT-Grundschutz-Kompendium*. Edition 2023. Köln : Reguvis, 2023. ISBN 978-3-8462-0906-6.
4. S. O. Bradner. RFC 2119 - Key words for use in RFCs to Indicate Requirement Levels. [Online] März 1997. <https://www.rfc-editor.org/info/rfc2119>.
5. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-02102-1 - Kryptographische Verfahren: Empfehlungen und Schlüssellängen. [Online] 31. Januar 2025. <https://www.bsi.bund.de/dok/TR-02102>.
6. Bundesministerium der Justiz und für Verbraucherschutz. Handbuch der Rechtsförmlichkeit (3. Auflage). [Online] 22. September 2008. https://www.bmjv.de/SharedDocs/Publikationen/DE/Fachpublikationen/Handbuch_der_Rechtsfoermlichkeit.html.
7. Bundesamt für Sicherheit in der Informationstechnik. BSI-Standard 200-1: Managementsysteme für Informationssicherheit (ISMS). [Online] 15. November 2017. <https://www.bsi.bund.de/dok/10027834>.
8. —. BSI-Standard 200-2: IT-Grundschutz-Methodik. [Online] 15. November 2017. <https://www.bsi.bund.de/dok/10027846>.
9. —. BSI-Standard 200-3: Risikomanagement. [Online] 15. 11 2017. <https://www.bsi.bund.de/dok/10027822>.
10. International Organization for Standardization (Hrsg.). *ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements*. 2022.
11. Bundesamt für Sicherheit in der Informationstechnik. BSI-Standard 200-4: Business Continuity Management. [Online] 2023. https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-4-Business-Continuity-Management/bsi-standard-200-4_Business_Continuity_Management_node.html.
12. International Organization for Standardization (Hrsg.). *ISO 22301:2019, Security and resilience - Business continuity management systems - Requirements*. 2019.
13. Foudil, Edwin und Shafranovich, Yakov. RFC 9116 - A File Format to Aid in Security Vulnerability Disclosure. [Online] April 2022. <https://www.rfc-editor.org/info/rfc9116>.
14. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-03185 - Sicherer Software-Lebenszyklus. [Online] 2025. <https://www.bsi.bund.de/dok/TR-03185>.
15. —. BSI TR-03183 - Cyber-Resilienz-Anforderungen: Teil 2 "Software Bill of Materials (SBOM)". [Online] 20. August 2025. <https://www.bsi.bund.de/dok/TR-03183>.
16. IT-Planungsrat. 31. Sitzung am 25.03.2020: Beschluss 2020/06 zum SDM. [Online] <https://www.it-planungsrat.de/beschluss/beschluss-2020-06>.
17. Bundesamt für Sicherheit in der Informationstechnik. Mindeststandard des BSI zur Protokollierung und Detektion von Cyberangriffen. [Online] November 2024. <https://www.bsi.bund.de/dok/MST-PD>.
18. —. Key Lifecycle Security Requirements - Version 1.0.3. [Online] 17. November 2021. <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/ElekAusweise/CVCA/KeyLifecycleSecurityRequirements.html>.

19. —. BSI TR-02102-2 - Kryptographische Verfahren: Verwendung von Transport Layer Security (TLS). [Online] 21. Januar 2025. <https://www.bsi.bund.de/dok/TR-02102>.
20. —. BSI TR-03116 - Kryptographische Vorgaben für Projekte der Bundesregierung: Teil 4 - Kommunikationsverfahren in Anwendungen. [Online] 07. März 2023. <https://www.bsi.bund.de/dok/TR-03116>.
21. Internet Engineering Task Force (IETF). RFC 9110 - HTTP Semantics. [Online] Juni 2022. <https://www.rfc-editor.org/rfc/rfc9110.html>.
22. Bundesverwaltungsamt. Spezifikation XBasisdaten 1.5. [Online] 31. Januar 2024. https://www.xrepositary.de/details/urn:xoev-de:bva:standard:xbasisdaten_1.5.
23. Bundesamt für Sicherheit in der Informationstechnik. BSI TR-02102 Kryptographische Verfahren: Empfehlungen und Schlüssellängen. [Online] <https://www.bsi.bund.de/dok/TR-02102>.
24. —. TR-03107 - Elektronische Identitäten und Vertrauensdienste im E-Government - Teil 1: Vertrauensniveaus und Mechanismen - Version 1.1.1. [Online] 7. Mai 2019. <https://www.bsi.bund.de/dok/TR-03107>.

Abkürzungsverzeichnis

Abkürzung	Erklärung
ALG	Application Level Gateway
beWiNr	Bundeseinheitliche Wirtschaftsnummer für Unternehmen
BSI	Bundesamt für Sicherheit in der Informationstechnik
BVA	Bundesverwaltungsamt
BVS	Betriebsverantwortliche Stelle
BZSt	Bundeszentralamt für Steuern
DAMAS	Datenmanagementsystem
DC	Data Consumer
DP	Data Provider
EU-DSGVO	Europäische Datenschutz-Grundverordnung
EU-OOTS	Once-Only-Technical-System der Europäischen Union
FVS	Fachverantwortliche Stelle
HTTPS	HyperText Transfer Protocol - Secure
IAM	Identity and Access Management
IDM	Identity Management
IDA	Identitätsdatenabruf
IDNr	Identifikationsnummer im Sinne des Identifikationsnummerngesetzes
IDNrG	Identifikationsnummerngesetz
NOOTS	Nationales Once-Only-Technical-System
OZG	Onlinezugangsgesetz
PAP-Struktur	Mehrstufige Sicherheitsarchitektur aus Paketfilter (P), ALG (A) und einem weiteren Paketfilter (P)
PKI	Public Key Infrastruktur
RDN	Registerdatennavigation
SAK	Sicherer Anschlussknoten
SDG	Single Digital Gateway
StBA	Statistisches Bundesamt
TDDs	Technical Design Documents – Technische Entwurfsdokumente
TLS	Transport Layer Security
TR	Technische Richtlinie
UBRegG	Unternehmensbasisdatenregistergesetz
VS	Vermittlungsstelle